CASE STUDY

The Year 2021 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

For the people who defend networks, 2021 was the year the edge gave way. Mail servers, VPN concentrators, file-transfer appliances, remote-management platforms and help-desk portals that sat on the internet were exploited one after another, often before a patch existed, and often by several unrelated crews within days of each other. State services from China, Russia, Iran and North Korea ran long campaigns, the Chinese, Russian and Iranian ones often through those same doors. Ransomware crews turned their access into a five-day pipeline shutdown, a national health service forced offline and an $11 million payment by a meat producer, and one of them reached fewer than 1,500 downstream businesses through a single IT management product. A commercial spyware vendor's zero-click iPhone exploit was caught in the wild. And governments answered with binding action: four CISA emergency directives, an executive order, a public catalog of exploited vulnerabilities with deadlines, sanctions on a cryptocurrency exchange, and joint attributions that NATO and the EU joined.

This study is the dated record of that year. It is a chronicle, not a deep dive: the largest single events have their own studies, and this one summarizes them in a paragraph and links. The Exchange mass exploitation is told in the Operation Exchange Marauder study, the SolarWinds campaign in the SolarWinds study, APT41's 2021 state-government intrusions in the APT41 study, Log4Shell in the Log4Shell study, and the Accellion extortion wave as the opening act of the Cl0p file-transfer study. Everything else in 2021 that the verified record supports is here, in date order, with the source behind each line.

Evidence grade: the events, attributions, directives and sanctions are **Confirmed** from the government agency, the vendor that observed the activity, the victim, or the CVE, NVD and KEV records. A few figures that reached the record only through a secondary source (the Avaddon key release, the alleged Conti playbook leaker, the third-party ransom statistics inside the Ransomware Task Force report, and Brian Krebs's retraction of his Ubiquiti reporting) are **Reported**. Public research that showed a cloud flaw without in-the-wild abuse is **Demonstrated**. Where this study draws its own conclusion or maps behavior to ATT&CK on its own reading, it says **Inferred**.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2021, with lead-in events from December 2020 and policy follow-through to 2022
State attributions made public by governments	Lazarus Group for AppleJeus on behalf of the DPRK, 17 February [31]; SVR (APT29) for SolarWinds, 15 April [9]; the Ministry of State Security for the Exchange zero-days, 19 July, joined by the EU, UK and NATO [4][18]; an Iranian government-sponsored APT, 17 November [25]
Emergency directives from CISA	ED 21-02 Exchange (3 March), ED 21-03 Pulse Connect Secure (20 April), ED 21-04 Print Spooler (13 July), ED 22-02 Log4j (17 December) [2][6][71][73]
Largest single ransomware events	Colonial Pipeline, 7 May, 5,500 miles shut [45]; Ireland's HSE, 14 May, most systems shut [47]; JBS, FBI attribution 2 June, $11 million paid [48][49]; Kaseya VSA, 2 July, fewer than 60 direct customers and fewer than 1,500 downstream businesses [51]
Policy landmarks	Executive Order 14028, 12 May [36]; NTIA SBOM minimum elements, 12 July [121]; control-systems memorandum, 28 July [130]; BOD 22-01 and the KEV catalog, 3 November [37]
KEV on its first day	287 entries in today's feed carry the 3 November 2021 date, 107 of them CVE-2021 ids; 311 entries were added during 2021 (computed from catalog version 2026.11.03) [41]
Top routinely exploited flaws of 2021	Log4Shell first, then ProxyLogon, ProxyShell, ManageEngine, Confluence, VMware vCenter, Zerologon, Pulse and Fortinet, per the five-country AA22-117A [74]
ATT&CK during the year	v9 on 29 April (added HAFNIUM, folded UNC2452 into APT29); v10 on 21 October (added data sources) [131][132]
This study's MITRE binding	93 Enterprise and 3 ICS technique rows, 42 group, software and campaign objects, 8 CWE-to-CAPEC pairings, and two Navigator layers (Part 9)

Key findings

- **The edge was the front door.** Nine internet-facing products were exploited for first access during the year, most of them as zero-days or within weeks of a fix: Exchange, Pulse Connect Secure, Fortinet, SonicWall, Accellion, Serv-U, ManageEngine, Confluence and Kaseya VSA (Confirmed [1][5][25][76][39][20][21][81][51]). Calling T1190 Exploit Public-Facing Application the dominant initial access technique of 2021 for those actors is this study's reading (Inferred [74]).
- **Zero-days, then everyone.** ESET counted at least 10 groups on Exchange servers, four of them starting before Microsoft's 2 March patch (Confirmed [64]). Microsoft then saw ransomware, a botnet and a

cryptominer use the same flaws (Confirmed [3]). Pulse, Accellion and SonicWall followed a similar shape: a quiet zero-day campaign, then a public advisory (Confirmed [5][39][76]); whether broad use followed is not in the record.

- **Ransomware became a national-security problem.** Colonial Pipeline had all 5,500 miles of its pipeline shut by 6:10 AM on 7 May, a little over an hour after finding a ransom note (Confirmed [45]). The response that followed was no longer only advice: TSA security directives for pipelines, Treasury sanctions on two exchanges, rewards of up to $10 million for REvil leaders, and a federal bank-regulator 36-hour notification rule (Confirmed [126][127][59][61][128]).
- **One product, many victims.** The REvil attack through Kaseya VSA used the product's own deployment function to push ransomware to endpoints; DIVD had reported the flaws in April and three were still open on 2 July (Confirmed [52][53]). The same lesson ran through Codecov's altered uploader, the ua-parser-js package and Nobelium's turn to resellers and their delegated admin rights (Confirmed [90][108][17]).
- **Identity was the second front.** Pulse appliances were trojanized to accept a backdoor password and bypass MFA (Confirmed [5]); Nobelium password-sprayed customer accounts with three entities compromised (Confirmed [15]), and its FoggyWeb backdoor sent out AD FS token-signing and decryption certificates (Confirmed [16]); Iranian operators sprayed Office 365 tenants of defense firms (Confirmed [26]).
- **Defenders became targets.** North Korean operators built a fake research blog and handed security researchers a booby-trapped Visual Studio project (Confirmed [29][30]), and Iranian operators impersonated SOAS scholars to harvest credentials (Confirmed [27]).
- **Spyware was caught in the act.** Citizen Lab captured NSO Group's FORCEDENTRY zero-click iMessage exploit on an activist's phone, Apple patched it the same day, and Apple sued NSO in November (Confirmed [34][35]). The Pegasus Project's list of about 50,000 numbers shows selection, not proven infection (Confirmed [33]).
- **Governments started publishing deadlines.** BOD 22-01 turned "patch what is exploited" into a catalog with due dates, and the catalog has outlived the directive: the BOD 22-01 page now marks it revoked and superseded by BOD 26-04 (Confirmed [37]).

Top recommendations

1. **Treat internet-facing management and access products as tier-zero assets.** Inventory them, subscribe to their vendors' advisories, and patch them on the KEV clock, not the monthly cycle (Inferred from [37][74]).
2. **Assume a patched edge device may already be owned.** Pulse integrity checks, Fortinet's instruction to reset passwords even after patching, and the ProxyLogon triage scripts all exist because patching does not remove a web shell or a stolen credential (Confirmed [6][78][2]).
3. **Retire legacy remote access.** Colonial's attacker is believed to have used a VPN profile that was not meant to be in use (Confirmed [45]). Every remote-access path should have an owner, MFA and a review date (Inferred).
4. **Give remote-management and CI tooling the same scrutiny as domain controllers.** A tool that can push software to every endpoint is a ransomware delivery system if it is taken (Confirmed [52]; Inferred for the generalization).

5. **Watch identity infrastructure as closely as endpoints.** AD FS servers, token-signing certificates, delegated admin relationships and password-spray telemetry carried the year's quietest intrusions (Confirmed [16][17][15]).
6. **Plan for the ransomware day.** Offline backups, an OT-separation decision tree and a sanctions-aware payment policy were all lessons the year taught in public (Confirmed [46][59]; Inferred for the plan).

Scope and method

This study covers intrusions, exploited vulnerabilities, and the government response in calendar year 2021. It draws on CISA and FBI advisories and directives, the UK NCSC, Ireland's NCSC, Treasury and White House releases, court-backed action by Microsoft's Digital Crimes Unit, the victims' own statements and testimony (Colonial Pipeline, JBS, Kaseya, T-Mobile, Codecov, HashiCorp, Twitch, Meta), the vendors that observed the activity (Microsoft, Mandiant, ESET, Proofpoint, Google TAG, Cisco Talos, Red Canary, Wiz, Unit 42, UpGuard, Citizen Lab, Amnesty Tech, DIVD), the CVE, NVD, MSRC and KEV records, and the live MITRE ATT&CK pages and the library's own data files. Every source was opened on 3 November 2026; the MSRC and CISA ProxyShell records [66][67] were opened again on 10 November 2026. Quotations are kept to a few words.

Grade	Meaning
Confirmed	A primary source was opened: the agency, the victim, the vendor that observed the activity, a CVE, NVD, MSRC or KEV record, or the MITRE record itself
Reported	Known only through a secondary source whose original was not opened, such as a news report or a vendor figure relayed inside another organization's report
Demonstrated	A public reproduction exists: researchers showed the flaw working, without known in-the-wild abuse
Inferred	This study's own reasoning from the cited facts, labelled where it appears

How the record is routed:

- **Home studies.** Where another study in this series is the home for an event, this study gives one paragraph and a link. The home studies are named in the executive summary.
- **Attribution language.** Each source's confidence words ("high confidence", "assessed", "suspected", "highly likely") are carried through as written. A vendor's name for a group (HAFNIUM, NOBELIUM, ZINC, PHOSPHORUS) is used with the vendor's report; its ATT&CK group is given through the alias table in the library's data, and where the source itself does not name the ATT&CK group, that link is marked Inferred.
- **KEV dates.** CISA's catalog launched on 3 November 2021, so almost every older exploited CVE in this record shows that date. A KEV date of 3 November 2021 means "in the first load", not "first exploited that day" (Confirmed [37][41]).
- **What was not checked.** The BlackMatter shutdown notice (early November 2021), the hijack and shutdown of REvil's Tor site (October 2021), the DOJ seizure of part of Colonial's ransom (7 June 2021), and the DOJ charges against Yaroslav Vasinskyi and the seizure from Yevgeniy Polyanin (8 November 2021) were not opened at a primary source and are left out of the dated record. Treasury's 8 November release [61] was read through a fetched summary, not the full page. The date of Europol's release on five

REvil affiliates was not checked. The DOJ release on the four MSS hackers was not opened; this study relies on the White House statement that describes it.

Part 1: the year at a glance

One row per dated event or report. Grades and sources are given on each row; later Parts tell the longer stories.

Date	Event	Who (as the source names them)	Grade and source
2020-12-10	DEVCORE finds the Exchange SSRF later numbered CVE-2021-26855; CVE-2021-27065 follows on 30 December	DEVCORE researchers	Confirmed [62]
Mid-Dec 2020	Accellion FTA zero-days exploited to plant the DEWMODE web shell; the first is patched on 23 December	UNC2546	Confirmed [39][40]
2021-01-05	DEVCORE reports ProxyLogon to the Microsoft Security Response Center, acknowledged the next day	DEVCORE	Confirmed [62]
2021-01-11	Ubiquiti tells users of unauthorized access to its IT systems	Unnamed	Confirmed [88]
Jan 2021	SOAS University of London scholars impersonated to harvest credentials (Operation SpoofedScholars), since at least January	TA453, IRGC-supporting (Proofpoint, high confidence)	Confirmed [27]
2021-01-25	Google TAG reveals a campaign against security researchers using a fake blog and a malicious Visual Studio project	North Korea-based government-backed entity	Confirmed [29]
2021-01-27	Emotet's infrastructure taken over by eight countries' authorities	Emotet operators	Confirmed [38]
2021-01-28	Microsoft attributes the researcher campaign to ZINC, started mid-2020	ZINC (DPRK)	Confirmed [30]
2021-01-28	Earliest Nobelium activity in the Constant Contact mail campaign later exposed in May	NOBELIUM	Confirmed [12]
2021-01-31	Codecov's Bash Uploader first altered; changes recur in 108 windows until 1 April	Unnamed	Confirmed [90]
Late Jan 2021	Accellion victims receive extortion mail pointing to the CL0P leak site	UNC2582, FIN11 overlaps	Confirmed [39]
2021-02-04	NVD publishes SonicWall SMA100 CVE-2021-20016, exploited as a zero-day before the February 2021 patch, in UNC2447 intrusions that ran from November 2020 to February 2021	UNC2447	Confirmed [75][76]

Date	Event	Who (as the source names them)	Grade and source
2021-02-05	Someone in a US water utility's SCADA system raises sodium hydroxide; staff reverse it	Unidentified	Confirmed [92]
Feb 2021	FORCEDENTRY in use since at least February; Nobelium's new toolset seen as early as February	NSO Group (Citizen Lab, high confidence); NOBELIUM	Confirmed [34][13]
2021-02-17	AA21-048A describes seven versions of AppleJeus cryptocurrency malware	Lazarus Group (DPRK)	Confirmed [31]
2021-02-22	Mandiant publishes the Accellion data theft and extortion report; CISA's AA21-055A follows on 24 February	UNC2546, UNC2582	Confirmed [39][40]
2021-02-28 to 03-02	Exchange web shells from Tick (28 Feb), LuckyMouse and Calypso (1 Mar) and Winnti (2 Mar), before the patch	Several groups (ESET)	Confirmed [64]
2021-03-02	Microsoft ships Exchange fixes and attributes exploitation to HAFNIUM	HAFNIUM	Confirmed [1][63]
2021-03-03	CISA issues ED 21-02 for on-premises Exchange	US federal civilian agencies	Confirmed [2]
2021-03-10	ESET counts web shells on more than 5,000 Exchange servers in over 115 countries	At least 10 groups	Confirmed [64]
Mar 2021	Scanning of Fortinet SSL VPN ports for CVE-2018-13379 and enumeration for two more Fortinet flaws	APT actors (FBI, CISA); later tied to an Iranian government-sponsored APT	Confirmed [77][25]
2021-03-25	Microsoft reports DoejoCrypt ransomware, Pydomer and Lemon Duck on Exchange; over 92% of known Exchange IPs patched or mitigated	Criminal and state actors	Confirmed [3]
2021-03-28	Two malicious commits pushed to php-src under two core developers' names	Unnamed	Confirmed [93]
2021-04-01	Codecov learns its uploader was altered; DIVD opens its Kaseya VSA case	Unnamed; DIVD	Confirmed [90][54]
2021-04-02	FBI and CISA warn of Fortinet FortiOS exploitation (AA21-092A)	APT actors	Confirmed [24][77]
2021-04-06	Meta says the Facebook data set in the news was scraped before September 2019, not hacked; ZDI reports ProxyShell to Microsoft from Pwn2Own	Scrapers; researcher credited as orangetw	Confirmed [94][65]
2021-04-14	Ireland's DPC opens its Facebook scraping inquiry	Meta Platforms Ireland	Confirmed [95]

Date	Event	Who (as the source names them)	Grade and source
2021-04-15	The White House names the SVR for SolarWinds; Treasury sanctions six Russian technology companies; Codecov discloses publicly	SVR (APT29)	Confirmed [9][10][91]
2021-04-19	Mandiant reveals the Pulse Connect Secure zero-day CVE-2021-22893 and 12 malware families	UNC2630, UNC2717	Confirmed [5]
2021-04-20	CISA issues ED 21-03 and AA21-110A for Pulse Connect Secure	US agencies and critical infrastructure	Confirmed [6][7]
2021-04-21	The Ransomware Task Force publishes 48 recommendations	Institute for Security and Technology	Confirmed [42]
2021-04-22	HashiCorp rotates its GPG release-signing key exposed through Codecov	Codecov actor	Confirmed [91]
2021-04-26	AA21-116A describes SVR tradecraft, including WELLMESS against COVID-19 vaccine research	SVR (APT29)	Confirmed [11]
2021-04-29	ATT&CK v9 released; Mandiant details UNC2447's FIVEHANDS ransomware	MITRE; UNC2447	Confirmed [131][76]
2021-05-07	Colonial Pipeline finds a ransom note before 5:00 AM and shuts the pipeline by 6:10 AM	DarkSide (per the FBI)	Confirmed [45][44]
2021-05-11	AA21-131A on DarkSide; MSRC publishes CVE-2021-31207; MSRC later records the other two ProxyShell flaws as fixed by the April 2021 updates, and per CISA the May update remediates all three	DarkSide affiliates	Confirmed [46][66][67]
2021-05-12	Executive Order 14028 signed; Colonial begins restart that evening	US federal government; Colonial	Confirmed [36][45]
2021-05-13 to 05-14	Ireland's Department of Health and the HSE hit; most HSE systems shut	Human-operated Conti	Confirmed [47]
May 2021	Access to a US municipal government web server via Fortinet	Iranian government-sponsored APT	Confirmed [25]
2021-05-27	TSA Security Directive 1 for pipelines; Microsoft reveals Nobelium's USAID-spoofing mail campaign	DHS; NOBELIUM	Confirmed [126][12]
2021-05-28	Microsoft details EnvyScout, BoomBox, NativeZone and VaporRage; CISA and FBI publish AA21-148A	NOBELIUM	Confirmed [13][14]
2021-06-02	FBI attributes the JBS attack to REvil/Sodinokibi	REvil	Confirmed [48]
2021-06-08	MSRC releases CVE-2021-1675 (later known as part of PrintNightmare)	n/a	Confirmed [68]

Date	Event	Who (as the source names them)	Grade and source
2021-06-09	JBS USA says it paid the equivalent of $11 million; Colonial's CEO testifies to the House	REvil; Colonial	Confirmed [49][45]
2021-06-11	Avaddon shuts down and releases 2,934 decryption keys	Avaddon	Reported [50]
2021-06-13	EUROPIUM and DEV-0343 hit the same account the same day	Iranian actors (Microsoft)	Confirmed [26]
Jun 2021	Access to a US children's hospital's environmental control network	Iranian government-sponsored APT	Confirmed [25]
2021-06-24	NIST publishes the EO-critical software definition	NIST	Confirmed [120]
2021-06-25	Microsoft reports Nobelium password spraying and an info-stealer on a support agent's machine	NOBELIUM	Confirmed [15]
2021-06-30	CERT/CC warns that public PrintNightmare exploits beat the June update	Researchers' code	Confirmed [69]
2021-07-01	MSRC publishes CVE-2021-34527, exploited; Start of the 1 July to 19 October period in which Microsoft counted 22,868 Nobelium attacks on 609 customers	n/a; NOBELIUM	Confirmed [70][17]
2021-07-02	Kaseya shuts its SaaS and tells on-premises customers to shut VSA down; DIVD starts scanning	REvil	Confirmed [51][54]
2021-07-07	DIVD publishes its limited disclosure of seven Kaseya VSA CVEs	DIVD	Confirmed [53]
2021-07-11	Kaseya releases the on-premises VSA patch	Kaseya	Confirmed [51][56]
2021-07-12	NTIA publishes SBOM minimum elements	NTIA	Confirmed [121]
2021-07-13	ED 21-04 for the Print Spooler; Microsoft reveals Serv-U zero-day use; Proofpoint publishes SpoofedScholars; MSRC releases two more ProxyShell CVEs	DEV-0322; TA453	Confirmed [71][20][27][66]
2021-07-18 to 07-19	Amnesty's Pegasus forensic methodology and the Pegasus Project	NSO Group clients	Confirmed [32][33]
2021-07-19	The US, EU, UK and NATO attribute the Exchange zero-days to the MSS; AA21-200A on APT40	MSS, APT40, APT31	Confirmed [4][18][19]
2021-07-20	TSA Security Directive 2	DHS	Confirmed [127]
2021-07-21 or 22	Kaseya obtains a universal decryptor from a third party	Kaseya	Confirmed [51]
2021-07-26	Kaseya says it paid no ransom	Kaseya	Confirmed [51]

Date	Event	Who (as the source names them)	Grade and source
2021-07-28	National Security Memorandum on control systems; AA21-209A on 2021 perimeter targeting	White House; CISA and partners	Confirmed [130][79]
Jul 2021	BlackMatter first seen, a possible DarkSide rebrand	BlackMatter	Confirmed [60]
Aug 2021	Conti playbook leaked; ManageEngine ADSelfService Plus exploited from as early as August	Alleged leaker "m1Geelka"; APT actors	Reported [57]; Confirmed [21]
2021-08-12	Wiz reports the Cosmos DB notebook flaw to Microsoft	Wiz	Confirmed [102]
2021-08-17 to 08-27	T-Mobile confirms customer data theft and later describes brute-force access	Unnamed	Confirmed [99][100]
2021-08-18	Earliest MSHTML CVE-2021-40444 attack attempt	DEV-0413	Confirmed [84]
2021-08-21	CISA warns of active ProxyShell exploitation	Malicious actors	Confirmed [67]
2021-08-23	UpGuard reports 38 million records exposed through Power Apps portals	Configuration exposure	Confirmed [103]
2021-08-25	Atlassian discloses Confluence CVE-2021-26084; CISA warns of in-the-wild exploits on 3 September	n/a	Confirmed [80][81]
2021-08-26	Wiz publishes ChaosDB	Wiz research	Demonstrated [101]
2021-09-02	Cisco Talos translates the leaked Conti playbook	Conti affiliates	Confirmed [57]
2021-09-07	MSRC warns of MSHTML CVE-2021-40444 in targeted attacks; fixed 14 September	DEV-0413	Confirmed [83][84]
2021-09-08	Fortinet: SSL-VPN access data for 87,000 FortiGate devices disclosed	A malicious actor	Confirmed [78]
2021-09-09	Unit 42 publishes Azurescape	Unit 42 research	Demonstrated [106]
2021-09-13	Citizen Lab discloses FORCEDENTRY; Apple patches CVE-2021-30860	NSO Group	Confirmed [34]
2021-09-14	Wiz publishes OMIGOD	Wiz research	Confirmed [104]
2021-09-16	AA21-259A on ManageEngine CVE-2021-40539	APT actors	Confirmed [21]
2021-09-21	Treasury sanctions the SUEX exchange	SUEX OTC	Confirmed [59]
2021-09-22	AA21-265A on Conti	Conti	Confirmed [58]

Date	Event	Who (as the source names them)	Grade and source
2021-09-27	Microsoft discloses the FoggyWeb AD FS backdoor	NOBELIUM	Confirmed [16]
2021-09-29 to 10-07	Apache HTTP Server path traversal CVE-2021-41773, then the incomplete fix and CVE-2021-42013	Exploited in the wild	Confirmed [86]
2021-10-06	Twitch confirms a server configuration error exposed data	A malicious third party	Confirmed [107]
Oct 2021	ProxyShell exploited	Iranian government-sponsored APT	Confirmed [25]
2021-10-18	AA21-291A on BlackMatter	BlackMatter	Confirmed [60]
2021-10-21	ATT&CK v10 released	MITRE	Confirmed [132]
2021-10-22	Malicious ua-parser-js versions published to npm	Unnamed	Confirmed [108][109]
2021-10-24	Microsoft reveals Nobelium's targeting of resellers and service providers	NOBELIUM	Confirmed [17]
2021-11-03	BOD 22-01 creates the Known Exploited Vulnerabilities catalog	CISA	Confirmed [37][87][41]
2021-11-08	Treasury sanctions the Chatex exchange and two REvil affiliates; State offers rewards	REvil affiliates	Confirmed [61]
2021-11-16 to 11-17	Microsoft on Iranian actor trends; AA21-321A attributes Fortinet and ProxyShell activity to Iran	PHOSPHORUS, CURIUM, DEV-0343; Iranian government-sponsored APT	Confirmed [26][25]
2021-11-18	Bank regulators set a 36-hour incident notification rule	Federal Reserve, FDIC, OCC	Confirmed [128]
2021-11-23	Apple sues NSO Group	Apple	Confirmed [35]
2021-12-02 to 12-06	Microsoft seizes NICKEL websites under a court order	NICKEL	Confirmed [22]
2021-12-08	NVD publishes SonicWall SMA 100 CVE-2021-20038	n/a	Confirmed [41]
2021-12-10	Log4Shell published and added to KEV the same day	n/a (state actors named by Microsoft on 14 December [23])	Confirmed [72][41]
2021-12-14	Microsoft names HAFNIUM, PHOSPHORUS and groups from North Korea and Turkey using Log4Shell	Nation-state actors	Confirmed [23]
2021-12-17	CISA issues ED 22-02 for Log4j	US agencies	Confirmed [73]

Part 2: state operations

China

The longer record of the China-attributed groups named here (HAFNIUM, APT40, APT31, APT41 and others) is in China-Attributed Threat Actors: The Public Record; this section keeps to what happened in 2021.

Exchange (home: the Operation Exchange Marauder study). On 2 March 2021 Microsoft attributed in-the-wild exploitation of four Exchange flaws (CVE-2021-26855, -26857, -26858 and -27065) with high confidence to HAFNIUM, a group it assessed as state-sponsored and operating from China (Confirmed [1]). DEVCORE had found the first of the four in December 2020 and reported it on 5 January (Confirmed [62]). After access, HAFNIUM dropped ASP web shells, dumped LSASS with Procdump, packed data with 7-Zip, exported mailboxes with Exchange PowerShell snap-ins, used Nishang and PowerCat, and sent data to MEGA; its targets included infectious disease researchers, law firms, universities, defense contractors, think tanks and NGOs, mainly in the US (Confirmed [1]). ESET saw at least 10 groups on Exchange servers by 10 March, four of them before the patch (Confirmed [64]), and Microsoft later saw DoejoCrypt ransomware, Pydomer on about 1,500 systems, and Lemon Duck (Confirmed [3]). CISA's ED 21-02 ordered agencies to triage, patch or disconnect, with reports due at noon on 5 March and supplemental direction on 31 March and 13 April; the directive is now closed and its actions moved to BOD 22-01 (Confirmed [2]). On 19 July the US said with a high degree of confidence that MSS-affiliated operators exploited the zero-days, and the UK NCSC called HAFNIUM highly likely responsible (Confirmed [4][18]). ATT&CK records the group as G0125 HAFNIUM, whose aliases include Operation Exchange Marauder and Silk Typhoon (Confirmed [111]).

Pulse Connect Secure. Mandiant reported on 19 April that the then-unknown CVE-2021-22893 was being exploited together with older Pulse Secure flaws (Confirmed [5]). It tracked two clusters: UNC2630 against US Defense Industrial Base networks from August 2020 to March 2021, which Mandiant suspected acts for the Chinese government and may be linked to APT5 (unconfirmed), and UNC2717 against government agencies worldwide from October 2020 to March 2021, not tied to a state (Confirmed [5]). Mandiant tracked 12 malware families on the appliances: SLOWPULSE, LOCKPICK, PULSEJUMP, PACEMAKER, RADIALPULSE, PULSECHECK, SLIGHTPULSE, STEADYPULSE, ATRIUM, HARDPULSE, QUIETPULSE and THINBLOOD, not all tied to either cluster (Confirmed [5]). The techniques were appliance-native: a trojanized `libdsplibs.so` that accepted a backdoor password across LDAP, RADIUS, ACE and RealmSignin logins and so bypassed MFA, credential logging, web shells in admin pages, persistence across upgrades through `DSUpgrade.pm`, log clearing, and memory scraping by PACEMAKER (Confirmed [5]). CISA's AA21-110A dated the activity to June 2020 or earlier, said it reached US agencies, critical infrastructure and private companies, described timestomping of a trojanized `umount` binary, and noted traffic routed through compromised home NAS devices and small business routers (Confirmed [7]). ED 21-03 required agencies to run Pulse's Integrity Tool and isolate any appliance that failed it by 5 pm EDT on 23 April (Confirmed [6]). NVD scores CVE-2021-22893 at 10.0 with CWE-287 and CWE-416 (Confirmed [8]). The library's ATT&CK data gives G1023 APT5 the alias UNC2630 (Confirmed [134]); that is ATT&CK's choice, and Mandiant's 2021 report called the link unconfirmed.

APT40, APT31 and the July attribution. On 19 July the US, joined by the EU, the UK and NATO, attributed the Exchange exploitation to MSS-affiliated operators and said the PRC fostered contract hackers who ran ransomware, extortion, crypto-jacking and theft for profit (Confirmed [4]). The UK NCSC attributed APT40 and APT31 to the MSS and said it had given tailored advice to over 70 affected organisations (Confirmed [18]).

The White House statement describes DOJ charges against four MSS hackers for a multiyear campaign against maritime, aviation, defense, education and healthcare targets in at least a dozen countries, including theft of Ebola vaccine research (Confirmed [4]; the DOJ release itself was not opened). CISA's AA21-200A tied APT40, which ATT&CK records as G0065 Leviathan, to the MSS Hainan State Security Department through the front company Hainan Xiandun Technology Development Company and named three HSSD officers (Confirmed [19]). The advisory's own ATT&CK table runs from reconnaissance through exfiltration and is carried into Part 9 (Confirmed [19]). APT31 appears in the library as G0128 ZIRCONIUM through its alias table (Inferred link [134]).

Serv-U, ManageEngine and NICKEL. Microsoft attributed exploitation of the SolarWinds Serv-U flaw CVE-2021-35211 with high confidence to DEV-0322, a China-based group using commercial VPNs and compromised routers against the US Defense Industrial Base and software companies; the tell was `mshta`, `cmd` and PowerShell spawned from `Serv-U.exe` and a new global admin user (Confirmed [20]). This is a different product and a different actor from the Orion compromise (Confirmed [20]); see the SolarWinds study. CISA's AA21-259A said APT actors had likely exploited ManageEngine ADSelfService Plus CVE-2021-40539 since as early as August 2021, dropping a JSP web shell disguised as `service.cer` (Confirmed [21]); NVD lists CWE-706 and a 9.8 score (Confirmed [21]). On 6 December Microsoft's Digital Crimes Unit announced it had seized websites used by China-based NICKEL against targets in the US and 28 other countries, including foreign ministries, under a court order filed in the Eastern District of Virginia on 2 December; access had come through compromised VPN suppliers, spear-phished credentials and unpatched Exchange and SharePoint (Confirmed [22]). The library records NICKEL as an alias of G0004 Ke3chang (Confirmed [134]).

APT41 (home: the APT41 study). ATT&CK campaign C0017 records APT41 intrusions into at least six US state government networks from May 2021 to February 2022 (Confirmed [117]). That story belongs to the APT41 study.

Russia

The longer record of the Russia-attributed services and groups named here (the SVR, APT29 and NOBELIUM) is in Russia-Attributed Threat Actors: The Public Record; this section keeps to what happened in 2021.

SolarWinds attribution (home: the SolarWinds study). On 15 April the White House named the SVR, also known as APT29, Cozy Bear and The Dukes, as responsible for the SolarWinds campaign with high confidence, issued a new sanctions executive order and bond restrictions, sanctioned 32 entities and individuals over election interference and eight over Crimea, and expelled 10 Russian diplomats (Confirmed [9]). Treasury designated six Russian technology companies and said two of them, Pasit and SVA, supported SVR cyber operations (Confirmed [10]). ATT&CK records the campaign as C0024 SolarWinds Compromise, first seen August 2019 and last seen January 2021 (Confirmed [112]). The full story is in the SolarWinds study.

The SVR after SolarWinds. CISA's AA21-116A, published 26 April, assessed the SVR as APT29, called SolarWinds a departure from its historic tradecraft, and listed what it did otherwise: password spraying, exploitation of Citrix CVE-2019-19781, WELLMESS against COVID-19 vaccine research, Mimikatz and Cobalt Strike (Confirmed [11]). ATT&CK records the group as G0016 APT29, with NOBELIUM, UNC2452, Dark Halo and SolarStorm among its aliases (Confirmed [113]); ATT&CK v9 folded UNC2452 into it in April 2021 (Confirmed [131]).

The USAID-spoofing mail campaign. On 27 May Microsoft reported that NOBELIUM had sent mail through a Constant Contact account, spoofing USAID, to about 3,000 accounts at more than 150 organizations, with activity traced to 28 January (Confirmed [12]). The chain ran from an HTML attachment to an ISO image, a shortcut, and a DLL started by `rundll32`, leading to Cobalt Strike Beacon through NativeZone and to BoomBox, which used Dropbox (Confirmed [12]). The next day Microsoft described the toolset: EnvyScout, an HTML smuggling dropper; BoomBox, a Dropbox downloader that persisted through a Run key; NativeZone, a `rundll32` loader; and VaporRage, a shellcode downloader from compromised WordPress sites, seen as early as February (Confirmed [13]). CISA and the FBI's AA21-148A counted more than 7,000 accounts at about 350 government organizations, IGOs and NGOs, noted open-source attribution to APT29 without making its own, and mapped T1566.002, T1204.001, T1055.001 and T1105 (Confirmed [14]). The two counts differ; each is reported as its source states it.

Spraying, AD FS and resellers. In June Microsoft reported Nobelium password spraying and brute force, mostly unsuccessful, with three entities compromised; targets were 57% IT and 20% government across 36 countries, and an info-stealer on a Microsoft support agent's machine exposed basic information for a small number of customers (Confirmed [15]). In September it disclosed FoggyWeb, a passive AD FS backdoor loaded by DLL search-order hijacking through `version.dll` that sends out the AD FS configuration database and decrypted token-signing and token-decryption certificates, in use since April 2021 (Confirmed [16]). In October Microsoft said Nobelium had targeted resellers and technology service providers since May to abuse their delegated admin privileges: more than 140 notified, up to 14 possibly compromised, and, from 1 July to 19 October, 22,868 attacks against 609 customers with success in the low single digits; no vulnerability was used (Confirmed [17]).

Iran

Fortinet, Exchange and a children's hospital. The FBI and CISA warned on 2 April that APT actors were scanning for Fortinet CVE-2018-13379 on ports 4443, 8443 and 10443 and enumerating for CVE-2020-12812 and CVE-2019-5591 in March, likely to pre-position; the alert names no country (Confirmed [24][77]). On 17 November, AA21-321A from the FBI, CISA, Australia's ACSC and the UK NCSC attributed the activity to an Iranian government-sponsored APT and gave its arc: Fortinet scanning in March, access to a US municipal government web server in May, access to a US children's hospital's environmental control network in June, and ProxyShell CVE-2021-34473 exploitation from October (Confirmed [25]). Its ATT&CK table includes obtaining malware and tools, scheduled tasks, new local and domain accounts, archiving, and data encryption for impact (Confirmed [25]).

What Microsoft saw. At CyberWarCon, Microsoft described PHOSPHORUS scanning Fortinet and Exchange servers and then deploying BitLocker as ransomware, CURIUM running long-lived fake personas, and DEV-0343 password-spraying Office 365 tenants of defense, geographic information and maritime firms; EUROPIUM and DEV-0343 hit the same account on 13 June (Confirmed [26]). The library's alias table places PHOSPHORUS and TA453 under G0059 Magic Hound, CURIUM as G1012, and EUROPIUM under G0049 OilRig (Confirmed [134]; Microsoft's page does not name the ATT&CK groups, so the links are Inferred).

SpoofedScholars. Proofpoint attributed Operation SpoofedScholars to TA453, with high confidence that it supports the IRGC: since at least January the group impersonated SOAS University of London scholars and hosted a credential harvesting page on a compromised SOAS radio site (Confirmed [27]).

North Korea

Researchers as targets. On 25 January Google TAG attributed to a North Korea-based government-backed entity a campaign against security researchers that used a fake research blog, Twitter personas and a Visual Studio project whose build event ran a malicious DLL; some patched Windows 10 and Chrome visitors to the blog were also compromised, by a mechanism TAG had not confirmed (Confirmed [29]). Microsoft attributed the same campaign with high confidence to ZINC, starting in mid-2020, with the Comebacker malware (persisting through a Run key), Klackring (as a service), and abuse of the Vir.IT driver flaw CVE-2017-16238 (Confirmed [30]). ZINC is an alias of G0032 Lazarus Group in the library's ATT&CK data; Microsoft's page does not say Lazarus (Inferred link [30][134]).

AppleJeus. CISA, the FBI and Treasury's AA21-048A described seven AppleJeus versions disguised as cryptocurrency trading and wallet software (Celas Trade Pro, JMT Trading, Union Crypto, Kupay Wallet, CoinGoTrade, Dorusio and Ants2Whale), attributed to Lazarus on behalf of the DPRK, against targets in 32 countries since January 2020 (Confirmed [31]). ATT&CK records it as S0584 AppleJeus (Confirmed [134]). The advisory's macOS Launchd mapping (T1053.004) is deprecated in the library's v20.0 data and is left out (Confirmed [134]).

Commercial spyware

The Pegasus Project. Amnesty International's Security Lab published its forensic methodology on 18 July: Pegasus zero-click attacks from May 2018 to July 2021, including a July 2021 compromise of an iPhone 12 on iOS 14.6, network injection in Morocco in 2019 and 2020, about 700 Pegasus domains, and the release of the Mobile Verification Toolkit; Citizen Lab peer reviewed it (Confirmed [32]). The Pegasus Project, run by Forbidden Stories with more than 80 journalists from 17 outlets in 10 countries, rested on a leak of about 50,000 numbers; at least 180 journalists in 20 countries were selected as potential targets from 2016 to June 2021, 11 potential NSO client countries were named, and NSO denied the claims (Confirmed [33]). Selection on the list is not proof of infection (Confirmed [33]).

FORCEDENTRY. On 13 September Citizen Lab disclosed a zero-click iMessage exploit, an integer overflow in CoreGraphics reached through JBIG2 PDFs disguised as `.gif` files, found on a Saudi activist's phone, in use since at least February and attributed to NSO with high confidence; Apple patched CVE-2021-30860 the same day (Confirmed [34]). NVD lists CWE-190, and the flaw was in the first KEV load (Confirmed [34][41]). On 23 November Apple sued NSO Group and its parent for a permanent injunction and pledged $10 million plus any damages to cybersurveillance research and advocacy (Confirmed [35]). The library's ATT&CK software data has no Pegasus object, so this study makes no Mobile mapping (Confirmed [134]).

Part 3: ransomware and extortion

Emotet taken down. On 27 January, authorities in the Netherlands, Germany, the US, the UK, France, Lithuania, Canada and Ukraine took control of Emotet's infrastructure of several hundred servers, coordinated by Europol and Eurojust (Confirmed [38]). Emotet was a loader whose access was sold on, with TrickBot and Ryuk operators named; it arrived as Word attachments or links with an enable-macros lure, and Dutch police found a database of stolen e-mail credentials (Confirmed [38]). ATT&CK records S0367 Emotet and S0266 TrickBot (Confirmed [134]).

Accellion (home: the Cl0p file-transfer study). From mid-December 2020, UNC2546 exploited several zero-days in Accellion's legacy File Transfer Appliance to install the DEWMODE web shell, which listed and

downloaded files from the appliance's MySQL database and stripped log references; from late January victims received extortion mail threatening publication on the CL0P leak site, tracked as UNC2582 with FIN11 overlaps, and no ransomware was deployed (Confirmed [39]). CISA's AA21-055A listed the four flaws (CVE-2021-27101 to -27104), victims in medical, legal, telecom, finance, energy and government, and the appliance's end of life on 30 April 2021 (Confirmed [40]). The extortion-without-encryption model is the subject of the Cl0p file-transfer study. ATT&CK has S0611 Clop; DEWMODE, FIN11, UNC2546 and UNC2582 have no library ATT&CK object, and the library's G0092 TA505 aliases do not include FIN11 (Confirmed [134]).

The Ransomware Task Force. On 21 April the Institute for Security and Technology published its report *Combating Ransomware*, written by more than 60 experts, with 48 recommendations under four goals (deter, disrupt, help organizations prepare, respond) and five priority actions (Confirmed [42]). The report cites figures from third parties: nearly 2,400 US governments, healthcare facilities and schools hit in 2020 (Emsisoft), $350 million paid in 2020, up 311% (Chainalysis), and an average payment of $312,493, up 171% (Palo Alto Networks); those datasets were not opened here (Reported [43]).

Colonial Pipeline. The FBI confirmed that DarkSide ransomware was behind the compromise of Colonial Pipeline's networks (Confirmed [44]). Colonial's chief executive, Joseph Blount, told the House that the ransom note was found just before 5:00 AM EDT on Friday 7 May, the shutdown began at about 5:55 AM, and all 5,500 miles were shut by 6:10 AM; restart began on the evening of 12 May (Confirmed [45]). He testified that he decided to pay the ransom (the amount is not stated in the testimony), that the attacker is believed to have used a legacy VPN profile that was not meant to be in use, that the credential's source was still under investigation, and that Mandiant, Dragos and Black Hills Information Security were engaged (Confirmed [45]). CISA and the FBI's AA21-131A described DarkSide as ransomware-as-a-service with a developer revenue share; access by phishing, public-facing exploits and external remote services; RDP for persistence; Salsa20 and RSA encryption; data theft with leak threats; and C2 mostly over Tor with some Cobalt Strike (Confirmed [46]). It found no sign that operational technology was directly affected and said Colonial disconnected some OT as a precaution (Confirmed [46]). Details in the library's Notable Incidents entry that are not in the testimony (the missing MFA, the dark-web password, the $4.4 million figure and the 17 states) were not checked for this study. DarkSide has no software object in the library's ATT&CK data (Confirmed [134]).

Ireland's health service. Ireland's NCSC reported suspicious activity on the Department of Health network on 13 May, with Cobalt Strike Beacon suspected; at about 07:00 on 14 May the HSE incident, human-operated Conti, forced the shutdown of most HSE systems; a ransomware attempt on the Department of Health was detected and stopped; and the two were believed to be one campaign (Confirmed [47]). The alert lists 16 ATT&CK ids, one of them (T1082) under the wrong label, which this study carries with a note (Confirmed [47]).

JBS. The FBI attributed the attack on JBS to REvil/Sodinokibi (Confirmed [48]). JBS USA said on 9 June that it had paid the equivalent of $11 million and that most facilities were running when it paid (Confirmed [49]). ATT&CK records S0496 REvil and its operator G0115 GOLD SOUTHFIELD; neither live entry mentions Kaseya, and REvil's mapped techniques include T1486, T1490, T1489 and T1041 (Confirmed [98]).

Avaddon. BleepingComputer reported that Avaddon shut down and sent it 2,934 decryption keys, which Emsisoft and Coveware confirmed, and Emsisoft released a free decryptor (Reported [50]). ATT&CK records S0640 Avaddon (Confirmed [134]).

Kaseya VSA. Kaseya's notice log says that around midday on Friday 2 July it learned of a potential incident, shut its SaaS servers and told on-premises customers to shut VSA down, at 4:00 PM EDT by one reading of the log (Confirmed [51]). The counts settled at fewer than 60 Kaseya customers, all on-premises, directly

compromised and fewer than 1,500 downstream businesses affected; the on-premises patch shipped on 11 July; Kaseya obtained a universal decryptor from a third party (the log is read as 21 July in one pass and 22 July in another) with Emsisoft assisting, and on 26 July it stated it had not paid a ransom directly or indirectly (Confirmed [51]). Kaseya's technical notes say zero-days bypassed authentication and ran arbitrary commands, after which standard VSA functionality pushed ransomware to endpoints, with no evidence the VSA codebase was modified; indicators included `certutil.exe` copied as `cert.exe` decoding `agent.crt` to `agent.exe`, `mpsvc.dll` as the payload, and an IIS log sequence of `POST /dl.asp`, `/cgi-bin/KUpload.dll` and `/userFilterTableRpt.asp` (Confirmed [52]).

The Dutch Institute for Vulnerability Disclosure had found VSA flaws in early April and reported them: CVE-2021-30116 (credential leak and business logic), -30117 (SQL injection), -30118 (remote code execution, patched 10 April), -30119 (cross-site scripting), -30120 (2FA bypass), -30121 (local file inclusion) and -30201 (XML external entity); 30116, 30119 and 30120 were still open when the attack hit (Confirmed [53]). Its case ran from 1 April to 9 July, with scanning for exposed servers from 2 July and owner notifications from 3 July (Confirmed [54]). NVD records CVE-2021-30116 as credential disclosure exploited in the wild in July 2021, CWE-522, scored 9.8 by NVD and 10.0 by the CNA, in KEV with known ransomware use (Confirmed [55]); CVE-2021-30120 is CWE-669 with no KEV date (Confirmed [96]). CISA said it and the FBI had responded since 2 July to actors using the VSA flaw against MSPs and their customers, and published REvil's Kaseya C2 domains (Confirmed [56]). That Kaseya's MSP customers were reached through a trusted relationship and a deployment tool is this study's mapping (Inferred [51][52]).

The Conti playbook and advisory. Cisco Talos translated a leaked Conti playbook and the Cobalt Strike manual it references on 2 September, warning that the detail could let amateur actors run destructive attacks (Confirmed [57]); Talos, citing dark web information, named the alleged leaker as "m1Geelka", a lower-level member (Reported [57]). CISA, the FBI and NSA's AA21-265A counted more than 400 Conti attacks, updated on 28 February 2022 to more than 1,000; listed access by spearphishing, stolen or weak RDP credentials, phone calls, fake software, Router Scan brute force, TrickBot, IcedID and Cobalt Strike; and, per the leaked playbook, exploitation of 2017 SMB flaws, PrintNightmare (CVE-2021-34527) and Zerologon (CVE-2020-1472), with Rclone exfiltration and double extortion (Confirmed [58]). ATT&CK records S0575 Conti, S1040 Rclone and campaign C0015, an August 2021 intrusion using Bazar, Cobalt Strike and Conti that ATT&CK assesses as likely following the leaked playbook (Confirmed [118][134]). G0102 Wizard Spider, whose aliases include FIN12 and DEV-0193, is in the library, but no 2021 source opened here names it as Conti's operator, so it is listed for orientation only (Confirmed [116]).

BlackMatter. AA21-291A, from CISA, the FBI and NSA, said BlackMatter was first seen in July 2021 and was a possible rebrand of DarkSide (active September 2020 to May 2021); it hit multiple US critical infrastructure entities, including two food and agriculture organizations, with demands from $80,000 to $15,000,000 in Bitcoin and Monero, embedded stolen credentials, LDAP and SMB discovery, remote share encryption, a Linux encryptor for ESXi, and backup wiping (Confirmed [60]). BlackMatter has no library ATT&CK object (Confirmed [134]).

Following the money. On 21 September Treasury designated the exchange SUEX OTC under E.O. 13694, its first designation of a virtual currency exchange: SUEX had moved proceeds of at least eight ransomware variants, and over 40% of its known transactions were tied to illicit actors; Treasury also updated its advisory on the sanctions risk of facilitating payments and gave credit for prompt reporting to law enforcement (Confirmed [59]). On 8 November it designated the exchange Chatex, which was nested on SUEX and had

more than half its known transactions illicit or high-risk, and three firms that set up its infrastructure; it designated the REvil affiliates Yaroslav Vasinskyi, linked to the Kaseya attack, and Yevgeniy Polyanin; the State Department offered rewards of up to $10 million for REvil leaders and $5 million for affiliates, alongside actions in Latvia and Estonia and a FinCEN advisory update (Confirmed [61]). Europol's release on five Sodinokibi/REvil affiliates, suspected of about 7,000 infections and more than 200 million euros in demands, was readable by title only; its date was not checked (Confirmed [97]).

Part 4: the year of the exploited server

The five-country advisory AA22-117A, published in April 2022, ranked Log4Shell first among the top 15 routinely exploited vulnerabilities of 2021 and said proof-of-concept code appeared within two weeks of disclosure for most of the top flaws (Confirmed [74]). AA21-209A had already described 2021's focus on perimeter devices in July (Confirmed [79]). The table carries the flaws that the verified record ties to 2021 exploitation.

CVE	Product	Weakness (NVD unless noted)	First exploitation in the record	KEV added	Source
CVE-2021-26855	Exchange (ProxyLogon SSRF)	CWE-918, 9.1	Before the 2 March patch	2021-11-03, due 2022-05-03	Confirmed [1][63][41]
CVE-2021-26857	Exchange (UM deserialization)	CWE-502	Before 2 March	2021-11-03	Confirmed [1][41]
CVE-2021-26858	Exchange (post-auth file write)	NVD-CWE-noinfo	Before 2 March	2021-11-03	Confirmed [1][41]
CVE-2021-27065	Exchange (post-auth file write)	CWE-22	Before 2 March	2021-11-03	Confirmed [1][41]
CVE-2021-22893	Pulse Connect Secure	CWE-287, CWE-416, 10.0	Zero-day, reported 19 April	2021-11-03	Confirmed [5][8]
CVE-2021-20016	SonicWall SMA100	CWE-89, 9.8	Zero-day before the February patch	2021-11-03	Confirmed [75][76]
CVE-2021-27101 to -27104	Accellion FTA	27101 CWE-89 in KEV, NVD-CWE-Other in NVD; 27102 and 27104 CWE-78; 27103 CWE-918	Zero-days from mid-December 2020	2021-11-03, known ransomware use	Confirmed [40][41][110]
CVE-2018-13379	Fortinet FortiOS SSL VPN	CWE-22, 9.1	Scanned March 2021; 87,000 devices' credentials disclosed in September	2021-11-03, due 2022-05-03	Confirmed [77][78][79]
CVE-2021-31207, -34473, -34523	Exchange (ProxyShell)	CWE-434 (6.6); CWE-918; NVD-CWE-noinfo (9.0)	Active exploitation warned 21 August; Iranian use from October	2021-11-03, due 2021-11-17	Confirmed [67][25][28]

CVE	Product	Weakness (NVD unless noted)	First exploitation in the record	KEV added	Source
CVE-2021-1675, -34527	Windows Print Spooler (PrintNightmare)	No specific CWE	34527 exploited at publication on 1 July	2021-11-03; 34527 due 2022-05-03, 1675 due 2021-11-17; 34527 marked known ransomware use	Confirmed [70][41]
CVE-2021-30116	Kaseya VSA	CWE-522, 9.8 (NVD), 10.0 (CNA)	2 July	2021-11-03, known ransomware use	Confirmed [55]
CVE-2021-35211	SolarWinds Serv-U	CWE-787	Zero-day, reported 13 July	2021-11-03	Confirmed [20]
CVE-2021-26084	Atlassian Confluence (OGNL injection)	CWE-917	In the wild by 3 September	2021-11-03, due 2021-11-17	Confirmed [80][81][82]
CVE-2021-40444	Windows MSHTML	CWE-22	18 August	2021-11-03, due 2021-11-17	Confirmed [84][85]
CVE-2021-40539	ManageEngine ADSelfService Plus	CWE-706, 9.8	From as early as August	2021-11-03	Confirmed [21][41]
CVE-2021-41773, -42013	Apache HTTP Server 2.4.49 and 2.4.50	CWE-22	41773 known exploited at the 4 October fix; 42013 fixed 7 October	2021-11-03, due 2021-11-17	Confirmed [86]
CVE-2021-38647	Azure OMI (OMIGOD)	9.8	Disclosed 14 September; exploitation evidenced by the KEV listing	2021-11-03	Confirmed [104][105]
CVE-2021-30860	Apple CoreGraphics (FORCEDENTRY)	CWE-190, 7.8	Since at least February	2021-11-03	Confirmed [34]
CVE-2021-44228	Apache Log4j (Log4Shell)	CWE-20, CWE-400, CWE-502, CWE-917, 10.0	December	2021-12-10, due 2021-12-24	Confirmed [72]

SonicWall SMA 100 CVE-2021-20038 was published on 8 December 2021 and added to KEV on 28 January 2022; no 2021 exploitation is in the record (Confirmed [41]).

ProxyShell. The researcher ZDI credits as orangetw reported CVE-2021-34473 to Microsoft through Pwn2Own on 6 April, and ZDI published it on 19 July (Confirmed [65]). MSRC released CVE-2021-31207 on 11 May and CVE-2021-34473 and -34523 on 13 July, recording that those two had been addressed by the April 2021 updates but left out of the April release (Confirmed [66]); CISA's 21 August alert says the May 2021 update remediates all three (Confirmed [67]). The gap between the fix and the CVE publication is inferred from those dates (Inferred [66][67]). The same alert warned that malicious actors were actively exploiting the chain; it does not name LockFile (Confirmed [67]).

PrintNightmare. MSRC released CVE-2021-1675 on 8 June as not exploited (Confirmed [68]). On 30 June CERT/CC published VU#383432: public exploit code by Zhiniang Peng and Xuefeng Li, the June update did

not protect against it, and the workarounds were to disable the Spooler or set RestrictDriverInstallationToAdministrators (Confirmed [69]). Public proof-of-concept code exists (Demonstrated [69]). MSRC published CVE-2021-34527 on 1 July as exploited and publicly disclosed, CVSS 8.8, updating it on 6 and 7 July (Confirmed [70]). ED 21-04 required agencies to disable the Spooler on domain controllers by 14 July, apply the July updates by 20 July and report by 21 July (Confirmed [71]).

MSHTML. Microsoft dated the earliest CVE-2021-40444 attempt to 18 August, fewer than 10 attacks that month, by DEV-0413; the lure switched to a small claims court theme on 1 September, and the chain ran from a `.docx` external oleObject to MHTML, a CAB holding a DLL with an `.INF` extension, and a custom Cobalt Strike Beacon loader injected into `wabmig.exe`; overlapping DEV-0365 infrastructure also delivered Conti (Confirmed [84]).

SonicWall and UNC2447. Mandiant reported that UNC2447 exploited SonicWall CVE-2021-20016 as a zero-day before the February 2021 patch, in UNC2447 intrusions that ran from November 2020 to February 2021, deploying FIVEHANDS (a rewrite of DEATHRANSOM), SOMBRAT, HELLOKITTY, WARPRISM and BEACON (Confirmed [76]). Today's KEV feed holds seven SonicWall CVE-2021 entries (computed [41]).

Fortinet. On 8 September Fortinet said a malicious actor had disclosed SSL-VPN access information for 87,000 FortiGate devices obtained through CVE-2018-13379, and told customers to reset passwords even if they had patched (Confirmed [78]).

Apache HTTP Server. CVE-2021-41773 affected 2.4.49 only, was reported on 29 September and fixed in 2.4.50 on 4 October, was known exploited, and allowed remote code execution where CGI was enabled on aliased paths; the fix was incomplete, CVE-2021-42013 was reported on 6 October, and 2.4.51 shipped on 7 October (Confirmed [86]).

Log4Shell (home: the Log4Shell study). NVD published CVE-2021-44228 on 10 December with a 10.0 score, and CISA added it to KEV the same day with a 24 December due date (Confirmed [72]). CISA issued ED 22-02 on 17 December (Confirmed [73]). Microsoft's guidance, updated 14 December, listed HAFNIUM and Iran's PHOSPHORUS among the nation-state actors using it, alongside groups from North Korea and Turkey (Confirmed [23]). Its follow-on CVE-2021-45046 was added to KEV only on 1 May 2023 (Confirmed [41]). The rest is in the Log4Shell study.

Part 5: supply chain, cloud and data exposure

Codecov. Codecov learned on 1 April that its Bash Uploader had been altered; periodic changes began on 31 January, in 108 windows of time, and a customer noticed that the uploader's SHA checksum did not match the one on GitHub (Confirmed [90]). The cause was an error in Codecov's Docker image build that let the actor extract a Google Cloud Storage credential used to modify the script (Confirmed [90]). The altered uploader sent git remote information and CI environment variables to a third-party server; Codecov published three IP addresses as indicators (Confirmed [90]). HashiCorp said a subset of its CI pipelines used the component and that its GPG release-signing private key had been exposed and rotated, with no sign of misuse (Confirmed [91]).

php-src. On 28 March two malicious commits were pushed to php-src under the names of Rasmus Lerdorf and Nikita Popov; the evidence pointed to a compromise of `git.php.net`, and PHP moved its canonical repositories to GitHub and required 2FA (Confirmed [93]).

ua-parser-js. CISA said on 22 October that ua-parser-js versions 0.7.29, 0.8.0 and 1.0.0 contained malicious code, fixed in 0.7.30, 0.8.1 and 1.0.1 (Confirmed [108]). GitHub's advisory told anyone with the package installed to treat the machine as fully compromised and rotate secrets from a different computer (Confirmed [109]). See the npm supply-chain study for the longer pattern.

Ubiquiti. Ubiquiti told users on 11 January of unauthorized access to its IT systems, and later posted an update responding to Brian Krebs's reporting (Confirmed [88]; only the page summary was readable). In August 2022 Krebs wrote that his sole source for those articles had since been indicted, including for giving false information to the press, and he apologized and removed the articles (Reported [89]). The Ubiquiti record for 2021 therefore rests on the company's notice.

T-Mobile. On 17 August T-Mobile confirmed access to data on about 7.8 million current postpaid accounts and just over 40 million former or prospective customers (names, dates of birth, Social Security numbers and ID data), plus about 850,000 prepaid names, numbers and PINs; on 20 August it added 5.3 million more postpaid accounts (without Social Security numbers), 667,000 more former customers, and IMEI and IMSI data (Confirmed [99]). Its chief executive wrote on 27 August that Mandiant was engaged and that the actor reached testing environments and then used brute force attacks and other methods to reach IT servers holding customer data (Confirmed [100]).

Facebook scraping. Meta said on 6 April that the data set in the news was scraped through the contact importer before September 2019, not hacked, and that the feature was changed in 2019; the 530 million figure came from press reports, not Meta (Confirmed [94]). Ireland's DPC opened an inquiry on 14 April 2021 and on 25 November 2022 fined Meta Platforms Ireland 265 million euros under GDPR Articles 25(1) and 25(2) (Confirmed [95]).

Twitch. Twitch said on 6 October that data was exposed through an error in a server configuration change and accessed by a malicious third party; stream keys were reset on 7 October, and on 15 October it said passwords and full card or bank data were not exposed, and the data was mainly source code repository documents and some creator payout data (Confirmed [107]).

Cloud research. Several 2021 cloud flaws were first shown by researchers. ChaosDB and Azurescape have no known in-the-wild abuse; OMIGOD's CVE-2021-38647 was later listed in KEV. Wiz's ChaosDB showed that Cosmos DB primary keys could give full read, write and delete across tenants; Microsoft disabled the notebook feature within 48 hours and notified over 30% of Cosmos DB customers (Demonstrated [101]). MSRC said Wiz reported it on 12 August, it was mitigated immediately, there was no evidence of third-party access, and affected customers were told to regenerate their keys (Confirmed [102]). Wiz's OMIGOD disclosed four flaws in the OMI agent, including CVE-2021-38647, an unauthenticated remote code execution as root scored 9.8, and Wiz said over 65% of the Azure customers it sampled were exposed (Confirmed [104][105]). Unit 42's Azurescape showed a cross-account container takeover in Azure Container Instances, patched with no known in-the-wild exploitation (Demonstrated [106]). UpGuard notified 47 entities whose Power Apps portals exposed public OData feeds, 38 million records in all, including COVID-19 contact tracing and vaccination data, among them Indiana, Maryland, New York City, American Airlines, J.B. Hunt and Microsoft (Confirmed [103]).

Part 6: industrial and critical infrastructure

A water utility's SCADA system. CISA's AA21-042A says that on 5 February unidentified actors reached the SCADA system of a US drinking water facility and raised the sodium hydroxide setting; staff noticed and reversed it at once, and treatment was not affected (Confirmed [92]). It names poor password security and an outdated Windows 7 system as likely weaknesses and says desktop sharing software such as TeamViewer may have been used, which cannot be confirmed (Confirmed [92]). The advisory as published today says the FBI could not confirm that the incident was a targeted intrusion; whether that wording was in the February 2021 text was not checked, and the advisory does not name Oldsmar (Confirmed [92]). The library has no generated ATT&CK for ICS pages, so the ICS rows in Part 9 are not linked (Confirmed [134]).

Colonial and the OT question. AA21-131A found no indication that Colonial's OT was directly affected; the shutdown was Colonial's own decision (Confirmed [46][45]). The pipeline stopped because the company chose to stop it, which is the case every OT owner now plans for (Inferred).

The government response. TSA Security Directive 1, announced 27 May, requires pipeline owners to report confirmed and potential incidents to CISA, name a 24/7 cybersecurity coordinator and finish a 30-day gap review (Confirmed [126]). Security Directive 2, announced 20 July, adds ransomware mitigations, a contingency and recovery plan, and an architecture design review (Confirmed [127]). The National Security Memorandum of 28 July created the Industrial Control Systems Cybersecurity Initiative, with preliminary performance goals due 22 September (Confirmed [130]). The Iranian access to a US children's hospital's environmental control network in June is part of the same picture (Confirmed [25]). For the longer ICS record see the Stuxnet study and the ICS Attack Atlas.

Part 7: the government record

Attribution and sanctions. Governments named state sponsors four times: Lazarus Group for the DPRK in AA21-048A on 17 February [31]; the SVR for SolarWinds on 15 April with sanctions and expulsions [9][10]; the MSS for the Exchange zero-days on 19 July, joined by the EU, UK and NATO, with DOJ charges and NCSC attribution of APT40 and APT31 [4][18][19]; and an Iranian government-sponsored APT on 17 November [25] (all Confirmed). Treasury's SUEX and Chatex designations extended sanctions to the payment layer of ransomware (Confirmed [59][61]).

Executive Order 14028. Signed on 12 May, the order covered threat-information sharing, zero trust and MFA, software supply chain security and SBOMs, the Cyber Safety Review Board, an incident response playbook, EDR and logging (Confirmed [36]). It set 60-day zero trust plans, MFA and encryption within 180 days, a 45-day critical software definition, 60-day SBOM minimum elements, the Board in Section 5, a 120-day playbook in Section 6, an EDR initiative in Section 7, logging in Section 8 and national security system equivalents in Section 9 (Confirmed [36]). Section 2 asked DHS to recommend contract language within 45 days with the most severe incidents reported within three days of detection (Confirmed [36]). NIST published the critical software definition in June and NTIA the SBOM minimum elements on 12 July: three areas (data fields, automation support, practices and processes), seven data fields, and SPDX, CycloneDX and SWID tags as formats (Confirmed [120][121][122]). CISA opened its Zero Trust Maturity Model 1.0 for comment in September (Confirmed [124]), and OMB's M-22-09 of 26 January 2022 set federal zero trust goals for the end of fiscal 2024, with phishing-resistant MFA for staff (Confirmed [123]). The Cyber Safety Review Board launched on 3 February 2022 and chose Log4j for its first review, not the December 2020 activity the order

had named (Confirmed [125]).

Emergency directives and BOD 22-01. CISA issued four emergency directives tied to 2021 flaws: ED 21-02 (Exchange), ED 21-03 (Pulse), ED 21-04 (Print Spooler) and ED 22-02 (Log4j) (Confirmed [2][6][71][73]). The first three were closed on 8 January 2026 with their actions moved to BOD 22-01 (Confirmed [2][6][71]). BOD 22-01, issued 3 November 2021, created the KEV catalog: remediate within two weeks for CVEs from 2021 on and within six months for older ones, update procedures within 60 days, and admit an entry only with a CVE id, clear remediation guidance and reliable evidence of exploitation (Confirmed [37]). CISA's press release quotes Director Easterly and does not give the first catalog's size (Confirmed [87]). Today's feed holds 287 entries dated 3 November 2021, of 1,767 in all; that is today's count for the date, not necessarily the launch size, since entries can be removed (Confirmed [41]; Inferred for the caveat). The BOD 22-01 page now marks the directive revoked and superseded by BOD 26-04 (Confirmed [37]).

Reporting rules. Federal bank regulators set a 36-hour computer-security incident notification rule on 18 November, with compliance by 1 May 2022 (Confirmed [128]). CIRCIA, passed in March 2022, sets 72-hour incident and 24-hour ransom payment reporting, and CISA's page still shows the final rule not issued (Confirmed [129]).

The ATT&CK framework itself. ATT&CK v9, from 29 April, reworked data sources, added Containers and Google Workspace, merged the AWS, GCP and Azure platforms into IaaS, added HAFNIUM and revoked UNC2452 into APT29 (Confirmed [131]). ATT&CK v10, from 21 October, added data source and data component objects; Enterprise then held 14 tactics, 188 techniques, 379 sub-techniques, 129 groups and 637 software (Confirmed [132]). D3FEND research is funded by the NSA Cybersecurity Directorate; its 2021 launch date was not checked (Confirmed [133]).

Part 8: the defender view

What the telemetry said. Red Canary's 2022 Threat Detection Report, built on its 2021 data, ranked techniques by the share of customers affected: Command and Scripting Interpreter (T1059) 53.4%, with PowerShell 35.0% and Windows Command Shell 28.1%; System Binary Proxy Execution (T1218) 34.8%, Rundll32 23.3%; Masquerading (T1036) 22.1%; Process Injection (T1055) 21.7%; Ingress Tool Transfer (T1105) 20.4%; Obfuscated Files or Information (T1027) 19.4%; OS Credential Dumping (T1003) 18.3%, LSASS Memory 13.3%; WMI (T1047) 15.4%; Scheduled Task/Job (T1053) 14.7%, Scheduled Task 12.2%; and Hijack Execution Flow (T1574) 8.4% (Confirmed [119]). It highlighted Cobalt Strike, Impacket, SocGholish, Yellow Cockatoo, Gootkit and BloodHound, with Qbot as initial access ahead of Egregor, REvil and Conti (Confirmed [119]). This is one vendor's view of its own customers, not the industry (Confirmed [119]).

Telling a patched server from a clean one. The 2021 directives kept saying the same thing: patching closes the door but does not evict whoever came through it. ED 21-02's supplemental direction required MSERT and `Test-ProxyLogon.ps1` triage runs (Confirmed [2]); ED 21-03 required the Pulse Integrity Tool and isolation on a mismatch (Confirmed [6]); Fortinet told customers to reset credentials after patching (Confirmed [78]). Pulse malware persisted across upgrades through `DSUpgrade.pm` (Confirmed [5]). A triage step that checks for web shells, new accounts and modified binaries belongs in every edge-device patch ticket (Inferred).

Hunting cues from the record.

- Web server or appliance processes spawning shells: `mshta`, `cmd` and PowerShell from `Serv-U.exe` [20]; JSP files dressed as certificates (`service.cer`) [21]; ASP web shells on Exchange [1] (Confirmed).
- Living-off-the-land tools in odd places: `certutil` renamed to `cert.exe` decoding an agent on Kaseya-managed hosts [52]; Procdump against LSASS [1]; `rundll32` started from an ISO-delivered shortcut [12] (Confirmed).
- Identity signals: password-spray patterns against Office 365 [15][26]; a new DLL beside the AD FS service (`version.dll`) [16]; new global admin users on file-transfer servers [20] (Confirmed).
- Supply chain signals: checksum mismatch on a downloaded CI script, which is how a Codecov customer caught the change [90]; unexpected package versions in a lockfile [108] (Confirmed).

Ransomware readiness. AA21-131A, AA21-265A and AA21-291A all list the same base controls: MFA on remote access, offline backups, network segmentation and prompt patching of public-facing services (Confirmed [46][58][60]; the list is this study's summary, Inferred). The HSE alert shows the value of catching the first Beacon: on the Department of Health network, where suspicious activity was seen on 13 May, a ransomware execution attempt was detected and stopped (Confirmed [47]).

Exposure management. KEV turned exploitation evidence into a work queue (Confirmed [37]). The 2021 lesson for vulnerability teams is that KEV's first load is a history of the previous several years, and the due dates CISA attached do not follow the directive's year rule mechanically: ProxyLogon and CVE-2021-34527 are 2021 ids yet carry six months, while ProxyShell and Confluence carry two weeks (Confirmed [41]); CISA's reason was not checked. See the library's Vulnerability Prioritization Reference.

Part 9: MITRE mappings

This Part binds the verified 2021 record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND, with every id checked against the library's data files (`data/attack/technique_profiles.jsonl`, `data/attack/ics/technique_profiles.jsonl`, `data/attack/superseded_by.jsonl`, `data/attack/technique_to_d3fend.jsonl`, `data/weaknesses/cwe.jsonl`) and the generated pages under `mitre/` on 3 November 2026 (Confirmed [134]). Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment.

Each row carries a basis. **Source** means an opened advisory or vendor report prints the ATT&CK id itself. **Behavior** means the source describes the behavior and this study assigns the id (the behavior is Confirmed; the mapping is this study's reading). **Inferred** means the behavior itself is this study's inference from the source.

ATT&CK Enterprise techniques

Id	Name	Tactic (v20.0)	Where it appears in the 2021 record	Basis	Source
T1589	Gather Victim Identity Information	Reconnaissance	AA21-200A table (APT40, 19 Jul)	Source	[19]
T1583.001	Acquire Infrastructure: Domains	Resource Development	AA21-200A table	Source	[19]
T1586.002	Compromise Accounts: Email Accounts	Resource Development	AA21-200A table	Source	[19]
T1585.001	Establish Accounts: Social Media Accounts	Resource Development	AA21-200A table; ZINC Twitter personas (Jan)	Source	[19][29][30]
T1585.002	Establish Accounts: Email Accounts	Resource Development	AA21-200A table	Source	[19]
T1588.001	Obtain Capabilities: Malware	Resource Development	AA21-321A table (Iran, 17 Nov)	Source	[25]
T1588.002	Obtain Capabilities: Tool	Resource Development	AA21-321A table	Source	[25]
T1595.002	Active Scanning: Vulnerability Scanning	Reconnaissance	Fortinet port scanning for CVE-2018-13379, March (AA21-092A, AA21-321A)	Behavior	[77][25]
T1190	Exploit Public-Facing Application	Initial Access	Mandiant Pulse mapping (19 Apr); AA21-200A; AA21-259A ManageEngine; AA21-131A DarkSide; AA21-321A; behavior in HAFNIUM Exchange (2 Mar), Serv-U (13 Jul), Accellion, SonicWall, Confluence, Kaseya VSA and SVR use of CVE-2019-19781	Source	[5][19][21][46][25][1][20][39][76][81][51][11]
T1133	External Remote Services	Persistence, Initial Access	AA21-200A; AA21-131A DarkSide; AA21-265A Conti; AA21-291A BlackMatter; legacy VPN profile at Colonial	Source	[19][46][58][60][45]
T1566	Phishing	Initial Access	AA21-131A DarkSide	Source	[46]
T1566.001	Phishing: Spearphishing Attachment	Initial Access	AA21-200A; AA21-265A; Emotet Word attachments (Jan); MSHTML Office lures (Aug to Sep)	Source	[19][58][38][84]
T1566.002	Phishing: Spearphishing Link	Initial Access	AA21-148A (28 May); AA21-200A; AA21-265A; NOBELIUM USAID-spoofing mail	Source	[14][19][58][12]
T1189	Drive-by Compromise	Initial Access	AA21-200A; visitors to the fake research blog (TAG, Jan)	Source	[19][29]

Id	Name	Tactic (v20.0)	Where it appears in the 2021 record	Basis	Source
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA21-200A; AA21-265A; legacy VPN profile at Colonial (May)	Source	[19][58][45]
T1199	Trusted Relationship	Initial Access	Nobelium abuse of resellers' delegated admin privileges (Oct); Kaseya MSP customers reached through VSA (Inferred)	Behavior	[17][51]
T1195.001	Supply Chain Compromise: Compromise Software Dependencies and Development Tools	Initial Access	Malicious ua-parser-js versions (22 Oct)	Behavior	[108][109]
T1195.002	Supply Chain Compromise: Compromise Software Supply Chain	Initial Access	Altered Codecov Bash Uploader (31 Jan to 1 Apr)	Behavior	[90][91]
T1059.001	Command and Scripting Interpreter: PowerShell	Execution	AA21-200A; Nishang and PowerCat (HAFNIUM); PowerShell from Serv-U.exe (DEV-0322)	Source	[19][1][20]
T1059.003	Command and Scripting Interpreter: Windows Command Shell	Execution	AA21-265A Conti; cmd from Serv-U.exe	Source	[58][20]
T1047	Windows Management Instrumentation	Execution	AA21-259A; Ireland NCSC HSE alert	Source	[21][47]
T1106	Native API	Execution	HSE alert; AA21-265A	Source	[47][58]
T1129	Shared Modules	Execution	HSE alert	Source	[47]
T1203	Exploitation for Client Execution	Execution	AA21-200A; MSHTML CVE-2021-40444 documents	Source	[19][84]
T1204.001	User Execution: Malicious Link	Execution	AA21-148A	Source	[14]
T1204.002	User Execution: Malicious File	Execution	AA21-200A; Emotet enable-macros lure; malicious Visual Studio project (ZINC)	Source	[19][38][29][30]
T1072	Software Deployment Tools	Execution, Lateral Movement	Standard VSA functionality pushed ransomware to endpoints (Kaseya, Jul)	Behavior	[52]
T1053.005	Scheduled Task/Job: Scheduled Task	Execution, Persistence, Privilege Escalation	AA21-321A	Source	[25]

Id	Name	Tactic (v20.0)	Where it appears in the 2021 record	Basis	Source
T1505.003	Server Software Component: Web Shell	Persistence	Mandiant Pulse mapping; AA21-200A; AA21-259A; HAFNIUM ASP web shells; DEWMODE on Accellion FTA	Source	[5][19][21][1][39]
T1554	Compromise Host Software Binary	Persistence	Trojanized Pulse libdsplibs.so and persistence across upgrades via DSUpgrade.pm	Behavior	[5]
T1136	Create Account	Persistence	AA21-259A; new global admin user on Serv-U	Source	[21][20]
T1136.001	Create Account: Local Account	Persistence	AA21-321A	Source	[25]
T1136.002	Create Account: Domain Account	Persistence	AA21-321A	Source	[25]
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	BoomBox Run key (NOBELIUM, May); Comebacker Run key (ZINC, Jan)	Behavior	[13][30]
T1543.003	Create or Modify System Process: Windows Service	Persistence, Privilege Escalation	Klackring installed as a service (ZINC)	Behavior	[30]
T1068	Exploitation for Privilege Escalation	Privilege Escalation	Vir.IT driver CVE-2017-16238 (ZINC); PrintNightmare CVE-2021-34527	Behavior	[30][69][70]
T1210	Exploitation of Remote Services	Lateral Movement	Conti playbook use of 2017 SMB flaws, PrintNightmare and Zerologon (AA21-265A)	Behavior	[58]
T1055.001	Process Injection: Dynamic-link Library Injection	Stealth, Privilege Escalation	AA21-148A; AA21-265A	Source	[14][58]
T1027	Obfuscated Files or Information	Stealth	AA21-259A; AA21-265A	Source	[21][58]
T1027.002	Obfuscated Files or Information: Software Packing	Stealth	HSE alert	Source	[47]
T1027.003	Obfuscated Files or Information: Steganography	Stealth	AA21-200A	Source	[19]
T1027.006	Obfuscated Files or Information: HTML Smuggling	Stealth	EnvyScout HTML smuggling (NOBELIUM)	Behavior	[13]

Id	Name	Tactic (v20.0)	Where it appears in the 2021 record	Basis	Source
T1036	Masquerading	Stealth	HSE alert; web shell disguised as service.cer (ManageEngine); certutil copied as cert.exe (Kaseya)	Source	[47][21][52]
T1140	Deobfuscate/Decode Files or Information	Stealth	AA21-259A; AA21-265A; cert.exe decoding agent.crt (Kaseya)	Source	[21][58][52]
T1218	System Binary Proxy Execution	Stealth	AA21-259A	Source	[21]
T1218.005	System Binary Proxy Execution: Mshta	Stealth	mshta spawned from Serv-U.exe (DEV-0322)	Behavior	[20]
T1218.011	System Binary Proxy Execution: Rundll32	Stealth	ISO to LNK to rundll32 DLL; NativeZone loader (NOBELIUM)	Behavior	[12][13]
T1564.003	Hide Artifacts: Hidden Window	Stealth	HSE alert	Source	[47]
T1497.001	Virtualization/Sandbox Evasion: System Checks	Stealth, Discovery	HSE alert	Source	[47]
T1574.001	Hijack Execution Flow: DLL	Stealth, Execution	FoggyWeb loaded through version.dll search-order hijacking (Sep)	Behavior	[16]
T1070	Indicator Removal	Stealth	Mandiant Pulse mapping (log clearing); DEWMODE cleanup routine	Source	[5][39]
T1070.004	Indicator Removal: File Deletion	Stealth	AA21-259A	Source	[21]
T1070.006	Indicator Removal: Timestomp	Stealth	Timestomped trojanized umount binary (AA21-110A)	Source	[7]
T1556.004	Modify Authentication Process: Network Device Authentication	Defense Impairment, Persistence, Credential Access	Mandiant Pulse mapping: backdoor password in libdsplibs.so	Source	[5]
T1111	Multi-Factor Authentication Interception	Credential Access	Mandiant Pulse mapping: MFA bypass	Source	[5]
T1110	Brute Force	Credential Access	AA21-265A; NOBELIUM brute force (Jun); T-Mobile brute force (Aug)	Source	[58][15][100]
T1110.003	Brute Force: Password Spraying	Credential Access	SVR password spraying (AA21-116A); NOBELIUM (Jun); DEV-0343 Office 365 spraying	Behavior	[11][15][26]

Id	Name	Tactic (v20.0)	Where it appears in the 2021 record	Basis	Source
T1003.001	OS Credential Dumping: LSASS Memory	Credential Access	AA21-291A BlackMatter; Procdump against LSASS (HAFNIUM)	Source	[60][1]
T1003.003	OS Credential Dumping: NTDS	Credential Access	AA21-259A	Source	[21]
T1558.003	Steal or Forge Kerberos Tickets: Kerberoasting	Credential Access	AA21-265A	Source	[58]
T1552	Unsecured Credentials	Credential Access	CI environment variables harvested by the altered Codecov uploader	Inferred	[90]
T1552.001	Unsecured Credentials: Credentials In Files	Credential Access	Credential extracted through Codecov's Docker image process	Inferred	[90]
T1552.004	Unsecured Credentials: Private Keys	Credential Access	AD FS token-signing and decryption certificates taken by FoggyWeb	Behavior	[16]
T1016	System Network Configuration Discovery	Discovery	HSE alert; AA21-265A	Source	[47][58]
T1049	System Network Connections Discovery	Discovery	HSE alert; AA21-265A	Source	[47][58]
T1057	Process Discovery	Discovery	HSE alert; AA21-265A; AA21-291A	Source	[47][58][60]
T1082	System Information Discovery	Discovery	HSE alert (printed under the wrong label)	Source	[47]
T1083	File and Directory Discovery	Discovery	HSE alert; AA21-265A	Source	[47][58]
T1087.002	Account Discovery: Domain Account	Discovery	AA21-259A	Source	[21]
T1124	System Time Discovery	Discovery	HSE alert	Source	[47]
T1135	Network Share Discovery	Discovery	HSE alert; AA21-265A	Source	[47][58]
T1018	Remote System Discovery	Discovery	AA21-291A	Source	[60]
T1007	System Service Discovery	Discovery	AA21-291A	Source	[60]
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral Movement	AA21-265A; AA21-291A	Source	[58][60]
T1534	Internal Spearphishing	Lateral Movement	AA21-200A	Source	[19]
T1080	Taint Shared Content	Lateral Movement	AA21-265A	Source	[58]
T1560	Archive Collected Data	Collection	AA21-200A	Source	[19]

Id	Name	Tactic (v20.0)	Where it appears in the 2021 record	Basis	Source
T1560.001	Archive Collected Data: Archive via Utility	Collection	AA21-259A; AA21-321A; 7-Zip archives (HAFNIUM)	Source	[21][25][1]
T1074	Data Staged	Collection	AA21-200A	Source	[19]
T1114.002	Email Collection: Remote Email Collection	Collection	Mailbox export through Exchange PowerShell snap-ins (HAFNIUM)	Behavior	[1]
T1105	Ingress Tool Transfer	Command and Control	AA21-148A	Source	[14]
T1001.003	Data Obfuscation: Protocol or Service Impersonation	Command and Control	AA21-200A	Source	[19]
T1572	Protocol Tunneling	Command and Control	AA21-200A	Source	[19]
T1090.003	Proxy: Multi-hop Proxy	Command and Control	AA21-200A; AA21-131A (DarkSide C2 over Tor)	Source	[19][46]
T1573.001	Encrypted Channel: Symmetric Cryptography	Command and Control	AA21-259A	Source	[21]
T1102	Web Service	Command and Control	BoomBox use of Dropbox (NOBELIUM)	Behavior	[13]
T1041	Exfiltration Over C2 Channel	Exfiltration	AA21-200A	Source	[19]
T1567	Exfiltration Over Web Service	Exfiltration	AA21-291A	Source	[60]
T1567.002	Exfiltration Over Web Service: Exfiltration to Cloud Storage	Exfiltration	Exfiltration to MEGA (HAFNIUM)	Behavior	[1]
T1486	Data Encrypted for Impact	Impact	AA21-131A; AA21-321A; HSE alert; AA21-265A; AA21-291A; Kaseya ransomware; PHOSPHORUS BitLocker	Source	[46][25][47][58][60][51][26]
T1490	Inhibit System Recovery	Impact	HSE alert; AA21-265A	Source	[47][58]
T1489	Service Stop	Impact	AA21-265A	Source	[58]
T1561	Disk Wipe	Impact	AA21-291A (backup wiping)	Source	[60]

Two ids printed in 2021 sources are left out: T1532 (an Enterprise id printed in AA21-200A that the library's v20.0 Enterprise data does not carry; the id now names a Mobile technique), and T1053.004 Launchd (AA21-048A) is deprecated in `superseded_by.jsonl` (Confirmed [19][31][134]). The live ATT&CK page for REvil lists the ICS sub-technique T1701.001 Command and Scripting Interpreter: PowerShell (T1701 was created 25 September 2026). The library's v20.0 ICS data carries T1701 and its sub-techniques but has no ICS software-to-technique rows, so REvil's ICS link is not in the library data. It is not mapped here because no

2021 REvil event in this record reached an industrial process (Confirmed [98][115][134]; Inferred for the exclusion). The HAFNIUM group page (version 3.0) merges the 2021 Exchange reporting with later Silk Typhoon reporting, so the rows above keep only what Microsoft's 2 March 2021 report supports (Confirmed [111][1]; Inferred for the filter).

ATT&CK for ICS techniques

Id	Name	Tactic (v20.0)	Where it appears in the 2021 record	Basis	Source
T0836	Modify Parameter	Impair Process Control	Sodium hydroxide setting raised through the SCADA system (5 Feb)	Behavior	[92]
T0822	External Remote Services	Initial Access	Desktop sharing software such as TeamViewer may have been used	Inferred	[92]
T0831	Manipulation of Control	Impact	Manipulation of the dosing process	Inferred	[92]

The library carries these ids in `data/attack/ics/technique_profiles.jsonl` but has no generated ATT&CK for ICS pages, so they are not linked (Confirmed [134]).

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to the 2021 record	Source
HAFNIUM	G0125	Exchange zero-days, 2 March; aliases include Operation Exchange Marauder	[1][111]
APT5	G1023	ATT&CK alias UNC2630 (Pulse); Mandiant's link was unconfirmed	[5][134]
APT29	G0016	SVR attribution, AA21-116A, NOBELIUM mail, password spray, FoggyWeb, resellers	[9][11][12][15][16][17][113]
SolarWinds Compromise	C0024	Attribution in April 2021; home is the SolarWinds study	[9][112]
SUNBURST	S0559	Object created 5 January 2021; home is the SolarWinds study	[114]
EnvyScout	S0634	HTML smuggling dropper, May 2021	[13]
BoomBox	S0635	Dropbox downloader, Run-key persistence	[13]
VaporRage	S0636	Shellcode downloader from compromised WordPress	[13]
NativeZone	S0637	`rundll32` loader for Cobalt Strike Beacon	[12][13]
FoggyWeb	S0661	AD FS backdoor, September 2021	[16]
WellMess	S0514	SVR use against COVID-19 vaccine research	[11]
Mimikatz	S0002	SVR tooling in AA21-116A	[11]
Cobalt Strike	S0154	SVR, NOBELIUM, DarkSide, HSE, Conti, MSHTML, UNC2447 BEACON	[11][12][46][47][58][84][76]
Covenant	S1155	Earlier HAFNIUM tooling	[1]
SLOWPULSE	S1104	Pulse authentication and MFA bypass	[5]
PULSECHECK	S1108	Pulse web shell	[5]
Leviathan (APT40)	G0065	AA21-200A, MSS Hainan State Security Department	[19]
ZIRCONIUM (APT31)	G0128	NCSC attribution to the MSS (alias link Inferred)	[18][134]
Ke3chang (NICKEL)	G0004	DCU website seizure, December	[22][134]
APT41	G0096	Home is the APT41 study	[117]
Campaign C0017	C0017	APT41 against US state governments, May 2021 to February 2022	[117]
Magic Hound	G0059	PHOSPHORUS and TA453 aliases: Fortinet and Exchange to BitLocker; SpoofedScholars; Log4Shell (alias links Inferred)	[26][27][23][134]

Object	Id and library page	Tie to the 2021 record	Source
CURIUM	G1012	Long-running fake personas	[26]
OilRig	G0049	EUROPIUM alias; same account as DEV-0343 on 13 June (alias link Inferred)	[26][134]
Lazarus Group	G0032	ZINC alias (Inferred); AppleJeus attribution (AA21-048A)	[30][31][134]
AppleJeus	S0584	Seven versions in AA21-048A	[31]
Emotet	S0367	Takedown, 27 January	[38]
TrickBot	S0266	Emotet access buyer; Conti access vector	[38][58]
Clop	S0611	Accellion extortion leak site	[39]
Tor	S0183	DarkSide C2	[46]
REvil	S0496	JBS, Kaseya	[48][56][98]
GOLD SOUTHFIELD	G0115	REvil operator in ATT&CK; the entry does not mention Kaseya	[98]
Avaddon	S0640	Shutdown and key release, June (Reported)	[50]
Conti	S0575	HSE, AA21-265A, playbook leak	[47][58][57][118]
Rclone	S1040	Conti exfiltration	[58]
Bazar	S0534	Campaign C0015	[134]
Campaign C0015	C0015	August 2021 Bazar, Cobalt Strike and Conti intrusion, likely following the leaked playbook	[134]
QakBot	S0650	Red Canary's leading initial access family before ransomware	[119]
FIVEHANDS	S0618	UNC2447 ransomware	[76]
SombRAT	S0615	UNC2447 backdoor	[76]
HELLOKITTY	S0617	UNC2447 ransomware	[76]
DEATHRANSOM	S0616	Base of FIVEHANDS	[76]

No ATT&CK campaign object covers the ProxyLogon wave, the 2021 Pulse activity, MSHTML, Colonial Pipeline, Kaseya, Codecov, Accellion, T-Mobile, Twitch or the water facility; that record sits on group and software objects (Confirmed for the data [134]; Inferred that none is pending). DarkSide, BlackMatter, DEWMODE, FIN11, UNC2546, UNC2582 and Pegasus have no library ATT&CK object (Confirmed [134]).

CWE and CAPEC

Weakness	CVEs in this record	CAPEC in the library	Source
CWE-918 Server-Side Request Forgery	CVE-2021-26855, -34473, -27103	CAPEC-664 Server Side Request Forgery	[41][28][110][134]
CWE-502 Deserialization of Untrusted Data	CVE-2021-26857, CVE-2021-44228 (CNA)	CAPEC-586 Object Injection	[41][72][134]
CWE-22 Path Traversal	CVE-2021-27065, CVE-2018-13379, CVE-2021-40444, -41773, -42013	CAPEC-126 Path Traversal	[41][85][86][134]
CWE-89 SQL Injection	CVE-2021-20016; CVE-2021-27101 (as KEV lists it)	CAPEC-66 SQL Injection	[75][41][134]
CWE-78 OS Command Injection	CVE-2021-27102, -27104	CAPEC-88 OS Command Injection	[110][134]
CWE-434 Unrestricted Upload	CVE-2021-31207	CAPEC-1, as the library relates it	[28][134]
CWE-287 Improper Authentication	CVE-2021-22893	CAPEC-115 Authentication Bypass, one of ten the library relates; the pick is this study's (Inferred)	[8][134]
CWE-190 Integer Overflow	CVE-2021-30860	CAPEC-92 Forced Integer Overflow	[34][134]
CWE-917 Expression Language Injection	CVE-2021-26084, CVE-2021-44228 (NVD)	None in the library	[82][72][134]
CWE-416, CWE-787, CWE-669	CVE-2021-22893, -35211, -30120	None in the library	[8][20][96][134]
CWE-522, CWE-706	CVE-2021-30116, -40539	Related CAPEC exist in the library; none is a clear fit, so none is bound here	[55][21][134]

The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	Library mappings to this study's techniques (`technique_to_d3fend.json`)	2021 guidance it matches	Source
Inbound Traffic Filtering	T1190, T1566.001, T1566.002	Blocking exploit traffic to edge devices while patching	[134][2]
Network Traffic Signature Analysis	T1190, T1199	Published IOCs for Kaseya and Pulse	[134][52][7]
File Integrity Monitoring	T1505.003, T1486, T1072, T1574.001	The Pulse Integrity Tool (ED 21-03); web shell sweeps	[134][6]
Executable Allowlisting	T1505.003, T1218.011	Blocking `rundll32` and web-shell payloads	[134][12]
Kernel-based Process Isolation	T1003.001, T1505.003	Protecting LSASS against Procdump	[134][1]
Process Spawn Analysis	T1003.001, T1218.011	Shells spawned by `Serv-U.exe` (Inferred pairing for T1059)	[134][20]
Multi-factor Authentication	T1110.003	MFA on remote access (AA21-131A, AA21-265A)	[134][46][58]
Credential Hardening	T1110.003	Password-spray defense	[134][15]
Credential Rotation	T1110.003	Fortinet's reset-after-patch advice; Codecov and ua-parser-js secret rotation (Inferred pairing for T1552)	[134][78][109]
Strong Password Policy	T1110.003	Water facility password weakness	[134][92]
Email Filtering	T1566.001, T1566.002	Emotet and NOBELIUM lures	[134][38][12]
Session Termination	T1133, T1199	Cutting legacy VPN and MSP sessions (Inferred pairing)	[134][45]
Software Inventory	T1195.001, T1195.002, T1072	SBOM minimum elements; finding Kaseya and Codecov exposure	[134][121]
Software Update	T1195.001, T1195.002, T1072	Fixed ua-parser-js versions; Kaseya patch	[134][108][51]
Restore File	T1486, T1072, T1574.001	Offline backups for ransomware recovery	[134][46]
Decoy File	T1486, T1505.003	Early ransomware detection (Inferred pairing)	[134]

No library D3FEND row exists for T1556.004, T1027.006 or T1059.001, so the Pulse authentication bypass, HTML smuggling and PowerShell rows have no bound countermeasure (Confirmed [134]).

Navigator layers

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/chronicle-2021.json, and the three ICS rows as navigator/case-studies/chronicle-2021-ics.json, both listed on the Navigator layers page. Open the Enterprise layer in the ATT&CK Navigator. Both are pinned to ATT&CK v20 and validated against the library's technique profiles (Confirmed [135]). Scores show the basis, not severity: 100 where an opened source prints the id, 70 where the source describes the behavior and this study assigns the id, and 40 for an Inferred behavior. Each entry's comment names the source numbers above, and each technique is shown under every tactic it has in v20.0.

Cross-cutting themes

- **Exploit first, attribute later.** The year's attributions came weeks to months after exploitation: the Exchange zero-days in March, the MSS named in July; Fortinet scanning in March, Iran named in November (Confirmed [1][4][77][25]). Defenders who waited for attribution to decide priority were late (Inferred). See Threat Actors.
- **Concentration risk.** One MSP tool reached fewer than 1,500 businesses; one CI script reached HashiCorp's signing key; resellers' delegated admin rights reached their customers (Confirmed [51][91][17]). The software that manages other software is the highest-value target (Inferred). See Supply Chain Security.
- **Ransomware met policy.** Colonial produced pipeline directives within three weeks, and by November Treasury was sanctioning exchanges and naming affiliates (Confirmed [126][59][61]).
- **The KEV idea outlasted its directive.** BOD 22-01 is now revoked and superseded by BOD 26-04, but the catalog it created is the reference every team in this record would recognize (Confirmed [37][41]).
- **Grading matters most where the story is loudest.** The Ubiquiti reporting was retracted by its author, the Pegasus list shows selection rather than infection, and the water-facility advisory now says the FBI could not confirm a targeted intrusion (Reported [89]; Confirmed [33][92]).

What is overstated and what is understated

- **Overstated: the water facility as a proven targeted attack.** The advisory says only what was seen on the SCADA system and, as published today, that the FBI could not confirm a targeted cyber intrusion (Confirmed [92]).
- **Overstated: the Pegasus Project list as a victim count.** The project rested on a leak of about 50,000 numbers, and at least 180 journalists were selected as potential targets; forensic confirmation of infection is a separate, smaller record (Confirmed [32][33]).
- **Understated: the edge-device persistence problem.** Pulse implants survived upgrades and Fortinet credentials stayed valid after patching (Confirmed [5][78]). A remediation metric that counts patches alone misses both (Inferred).
- **Understated: identity infrastructure.** FoggyWeb and the reseller campaign needed no new vulnerability at all (Confirmed [16][17]).

Discrepancies in the record

- **NOBELIUM mail counts.** Microsoft counted about 3,000 accounts at more than 150 organizations; AA21-148A counted more than 7,000 accounts at about 350 organizations (Confirmed [12][14]).
- **Kaseya decryptor date.** Two readings of Kaseya's notice log give 21 July and 22 July (Confirmed [51]).
- **Accellion CVE-2021-27101's weakness.** KEV lists CWE-89; NVD lists NVD-CWE-Other while describing SQL injection through the Host header (Confirmed [41][110]).
- **Kaseya CVE-2021-30116's score.** NVD scores 9.8 and the CNA 10.0 (Confirmed [55]).
- **KEV due dates.** ProxyLogon's CVEs and CVE-2021-34527 carry a six-month due date, while ProxyShell's and CVE-2021-1675 carry two weeks, though all are CVE-2021 ids added on the same day (Confirmed [41]).
- **HSE alert labels.** Ireland's NCSC alert prints T1082 under the wrong name (Confirmed [47]).

Sources

All sources were opened on 3 November 2026, except [66] and [67], which were opened again on 10 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here.

#	Source	URL	Opened	Grade
1	Microsoft Security, "HAFNIUM targeting Exchange Servers with 0-day exploits", 2 Mar 2021	microsoft.com	2026-11-03	Confirmed
2	CISA, ED 21-02 Mitigate Microsoft Exchange On-Premises Product Vulnerabilities, 3 Mar 2021 (also at ed-21-02-mitigate... and emergency-directive-21-02)	cisa.gov/ed2102	2026-11-03	Confirmed
3	Microsoft Security, "Analyzing attacks taking advantage of the Exchange Server vulnerabilities", 25 Mar 2021	microsoft.com	2026-11-03	Confirmed
4	The White House (archive), statement attributing malicious cyber activity to the PRC, 19 Jul 2021	bidenwhitehouse.archives.gov	2026-11-03	Confirmed
5	Mandiant (Google Cloud), "Check Your Pulse", on suspected APT actors and the Pulse Secure zero-day, 19 Apr 2021	cloud.google.com	2026-11-03	Confirmed
6	CISA, ED 21-03 Mitigate Pulse Connect Secure Product Vulnerabilities, 20 Apr 2021	cisa.gov	2026-11-03	Confirmed
7	CISA, AA21-110A Exploitation of Pulse Connect Secure Vulnerabilities, 20 Apr 2021	cisa.gov	2026-11-03	Confirmed
8	NVD, CVE-2021-22893 record (API)	services.nvd.nist.gov	2026-11-03	Confirmed
9	The White House (archive), fact sheet "Imposing Costs for Harmful Foreign Activities by the Russian Government", 15 Apr 2021	bidenwhitehouse.archives.gov	2026-11-03	Confirmed
10	US Treasury, press release jy0127, 15 Apr 2021	home.treasury.gov	2026-11-03	Confirmed
11	CISA, AA21-116A Russian Foreign Intelligence Service (SVR) Cyber Operations, 26 Apr 2021	cisa.gov	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
12	Microsoft Security, "New sophisticated email-based attack from NOBELIUM", 27 May 2021	microsoft.com	2026-11-03	Confirmed
13	Microsoft Security, "Breaking down NOBELIUM's latest early-stage toolset", 28 May 2021	microsoft.com	2026-11-03	Confirmed
14	CISA and FBI, AA21-148A Sophisticated Spearphishing Campaign Targets Government Organizations, IGOs, and NGOs, 28 May 2021	cisa.gov	2026-11-03	Confirmed
15	MSRC, "New Nobelium activity", 25 Jun 2021	microsoft.com	2026-11-03	Confirmed
16	Microsoft Security, "FoggyWeb: Targeted NOBELIUM malware leads to persistent backdoor", 27 Sep 2021	microsoft.com	2026-11-03	Confirmed
17	Microsoft On the Issues, "New activity from Russian actor Nobelium", 24 Oct 2021	blogs.microsoft.com	2026-11-03	Confirmed
18	UK NCSC, "UK and allies hold Chinese state responsible for a pervasive pattern of hacking", 19 Jul 2021	ncsc.gov.uk	2026-11-03	Confirmed
19	CISA, AA21-200A Tactics, Techniques, and Procedures of Indicted APT40 Actors Associated with China's MSS Hainan State Security Department, 19 Jul 2021	cisa.gov	2026-11-03	Confirmed
20	Microsoft Security, "Microsoft discovers threat actor targeting SolarWinds Serv-U software with 0-day exploit", 13 Jul 2021	microsoft.com	2026-11-03	Confirmed
21	CISA, AA21-259A APT Actors Exploiting Newly Identified Vulnerability in ManageEngine ADSelfService Plus, 16 Sep 2021	cisa.gov	2026-11-03	Confirmed
22	Microsoft On the Issues, NICKEL website seizure, 6 Dec 2021	blogs.microsoft.com	2026-11-03	Confirmed
23	Microsoft Security, guidance for CVE-2021-44228 Log4j 2 exploitation (nation-state update 14 Dec 2021)	microsoft.com	2026-11-03	Confirmed
24	CISA alert, FBI-CISA Joint Advisory on Exploitation of Fortinet FortiOS Vulnerabilities, 2 Apr 2021	cisa.gov	2026-11-03	Confirmed
25	FBI, CISA, ACSC and NCSC, AA21-321A Iranian Government-Sponsored APT Cyber Actors Exploiting Microsoft Exchange and Fortinet Vulnerabilities, 17 Nov 2021	cisa.gov	2026-11-03	Confirmed
26	Microsoft Security, "Evolving trends in Iranian threat actor activity", 16 Nov 2021	microsoft.com	2026-11-03	Confirmed
27	Proofpoint, "Operation SpoofedScholars", 13 Jul 2021	proofpoint.com	2026-11-03	Confirmed
28	NVD, CVE-2021-34473 record (API), with the ProxyShell and CVE-2018-13379 records	services.nvd.nist.gov	2026-11-03	Confirmed
29	Google Threat Analysis Group, "New campaign targeting security researchers", 25 Jan 2021	blog.google	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
30	Microsoft Security, "ZINC attacks against security researchers", 28 Jan 2021	microsoft.com	2026-11-03	Confirmed
31	CISA, FBI and Treasury, AA21-048A AppleJeus: Analysis of North Korea's Cryptocurrency Malware, 17 Feb 2021	cisa.gov	2026-11-03	Confirmed
32	Amnesty International Security Lab, "Forensic Methodology Report: How to catch NSO Group's Pegasus", 18 Jul 2021	amnesty.org	2026-11-03	Confirmed
33	Amnesty International, "The Pegasus Project", 19 Jul 2021	amnesty.org	2026-11-03	Confirmed
34	Citizen Lab, "FORCEDENTRY: NSO Group iMessage Zero-Click Exploit Captured in the Wild", 13 Sep 2021	citizenlab.ca	2026-11-03	Confirmed
35	Apple Newsroom, "Apple sues NSO Group to curb the abuse of state-sponsored spyware", 23 Nov 2021	apple.com	2026-11-03	Confirmed
36	The White House (archive), Executive Order 14028 on Improving the Nation's Cybersecurity, 12 May 2021	bidenwhitehouse.archives.gov	2026-11-03	Confirmed
37	CISA, BOD 22-01 Reducing the Significant Risk of Known Exploited Vulnerabilities, 3 Nov 2021	cisa.gov	2026-11-03	Confirmed
38	Eurojust, "World's most dangerous malware EMOTET disrupted through global action", 27 Jan 2021	eurojust.europa.eu	2026-11-03	Confirmed
39	Mandiant (Google Cloud), "Cyber Criminals Exploit Accellion FTA for Data Theft and Extortion", 22 Feb 2021	cloud.google.com	2026-11-03	Confirmed
40	CISA, AA21-055A Exploitation of Accellion File Transfer Appliance, 24 Feb 2021 (revised 17 Jun 2021)	cisa.gov	2026-11-03	Confirmed
41	CISA, Known Exploited Vulnerabilities catalog JSON feed, catalog version 2026.11.03	cisa.gov	2026-11-03	Confirmed
42	Institute for Security and Technology, Ransomware Task Force report page, 21 Apr 2021	securityandtechnology.org	2026-11-03	Confirmed
43	Institute for Security and Technology, "Combating Ransomware" report PDF (third-party figures inside)	securityandtechnology.org	2026-11-03	Reported
44	FBI, statement on compromise of Colonial Pipeline networks, 10 May 2021	fbi.gov	2026-11-03	Confirmed
45	Joseph Blount, testimony to the House Committee on Homeland Security, 9 Jun 2021	docs.house.gov	2026-11-03	Confirmed
46	CISA and FBI, AA21-131A DarkSide Ransomware: Best Practices for Preventing Business Disruption, 11 May 2021 (revised 8 Jul 2021)	cisa.gov	2026-11-03	Confirmed
47	Ireland NCSC, alert on Conti ransomware and the HSE, May 2021	ncsc.gov.ie	2026-11-03	Confirmed
48	FBI, statement on JBS cyberattack, 2 Jun 2021	fbi.gov	2026-11-03	Confirmed
49	JBS, media statement, 9 Jun 2021	jbsfoodsgroup.com	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
50	BleepingComputer, "Avaddon ransomware shuts down and releases decryption keys", 11 Jun 2021	bleepingcomputer.com	2026-11-03	Reported
51	Kaseya, "Important Notice July 2nd, 2021" (notice log)	helpdesk.kaseya.com	2026-11-03	Confirmed
52	Kaseya, "Incident Overview & Technical Details", Jul 2021	helpdesk.kaseya.com	2026-11-03	Confirmed
53	DIVD CSIRT, Kaseya limited disclosure, 7 Jul 2021	csirt.divd.nl	2026-11-03	Confirmed
54	DIVD CSIRT, case DIVD-2021-00002	csirt.divd.nl	2026-11-03	Confirmed
55	NVD, CVE-2021-30116 record (API; also the detail page)	services.nvd.nist.gov	2026-11-03	Confirmed
56	CISA, Kaseya ransomware attack guidance for affected MSPs and their customers, Jul 2021	cisa.gov	2026-11-03	Confirmed
57	Cisco Talos, "Translated: Talos' insights from the recently leaked Conti ransomware playbook", 2 Sep 2021	blog.talosintelligence.com	2026-11-03	Confirmed (leaker name Reported)
58	CISA, FBI and NSA, AA21-265A Conti Ransomware, 22 Sep 2021 (updated 28 Feb 2022)	cisa.gov	2026-11-03	Confirmed
59	US Treasury, press release jy0364 (SUEX), 21 Sep 2021	home.treasury.gov	2026-11-03	Confirmed
60	CISA, FBI and NSA, AA21-291A BlackMatter Ransomware, 18 Oct 2021	cisa.gov	2026-11-03	Confirmed
61	US Treasury, press release jy0471 (Chatex, REvil affiliates), 8 Nov 2021	home.treasury.gov	2026-11-03	Confirmed
62	DEVCORE, ProxyLogon disclosure site	proxylogon.com	2026-11-03	Confirmed
63	MSRC, CVE-2021-26855 record	api.msrc.microsoft.com	2026-11-03	Confirmed
64	ESET WeLiveSecurity, "Exchange servers under siege from at least 10 APT groups", 10 Mar 2021	welivesecurity.com	2026-11-03	Confirmed
65	Zero Day Initiative, ZDI-21-821	zerodayinitiative.com	2026-11-03	Confirmed
66	MSRC, CVE-2021-34473 record (with CVE-2021-31207 and -34523)	api.msrc.microsoft.com	2026-11-10	Confirmed
67	CISA alert, "Urgent: Protect Against Active Exploitation of ProxyShell Vulnerabilities", 21 Aug 2021	cisa.gov	2026-11-10	Confirmed
68	MSRC, CVE-2021-1675 record	api.msrc.microsoft.com	2026-11-03	Confirmed
69	CERT/CC, VU#383432 Microsoft Windows Print Spooler allows for RCE via AddPrinterDriverEx(), 30 Jun 2021	kb.cert.org	2026-11-03	Confirmed (PoC Demonstrated)
70	MSRC, CVE-2021-34527 record	api.msrc.microsoft.com	2026-11-03	Confirmed
71	CISA, ED 21-04 Mitigate Windows Print Spooler Service Vulnerability, 13 Jul 2021	cisa.gov	2026-11-03	Confirmed
72	NVD, CVE-2021-44228 record (API)	services.nvd.nist.gov	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
73	CISA, Apache Log4j vulnerability guidance	cisa.gov	2026-11-03	Confirmed
74	CISA and partners, AA22-117A 2021 Top Routinely Exploited Vulnerabilities, 27 Apr 2022	cisa.gov	2026-11-03	Confirmed
75	NVD, CVE-2021-20016 record (API)	services.nvd.nist.gov	2026-11-03	Confirmed
76	Mandiant (Google Cloud), "UNC2447 SOMBRAT and FIVEHANDS Ransomware: A Sophisticated Financial Threat", 29 Apr 2021	cloud.google.com	2026-11-03	Confirmed
77	FBI and CISA, AA21-092A joint advisory PDF on Fortinet FortiOS, 2 Apr 2021	ic3.gov	2026-11-03	Confirmed
78	Fortinet PSIRT, "Malicious Actor Discloses FortiGate SSL-VPN Credentials", 8 Sep 2021	fortinet.com	2026-11-03	Confirmed
79	CISA and partners, AA21-209A Top Routinely Exploited Vulnerabilities, 28 Jul 2021	cisa.gov	2026-11-03	Confirmed
80	Atlassian, Confluence Security Advisory 2021-08-25	confluence.atlassian.com	2026-11-03	Confirmed
81	CISA alert, Atlassian releases security updates for Confluence Server and Data Center, 3 Sep 2021	cisa.gov	2026-11-03	Confirmed
82	NVD, CVE-2021-26084 record (API)	services.nvd.nist.gov	2026-11-03	Confirmed
83	MSRC, CVE-2021-40444 record	api.msrc.microsoft.com	2026-11-03	Confirmed
84	Microsoft Security, "Analyzing attacks that exploit the CVE-2021-40444 MSHTML vulnerability", 15 Sep 2021	microsoft.com	2026-11-03	Confirmed
85	NVD, CVE-2021-40444 record (API)	services.nvd.nist.gov	2026-11-03	Confirmed
86	Apache HTTP Server 2.4 vulnerabilities page	httpd.apache.org	2026-11-03	Confirmed
87	CISA, press release on BOD 22-01, 3 Nov 2021	cisa.gov	2026-11-03	Confirmed
88	Ubiquiti community, "Update to January 2021 Account Notification" (summary readable)	community.ui.com	2026-11-03	Confirmed
89	KrebsOnSecurity, "Final Thoughts on Ubiquiti", 31 Aug 2022	krebsonsecurity.com	2026-11-03	Reported
90	Codecov, Bash Uploader security update	about.codecov.io	2026-11-03	Confirmed
91	HashiCorp, HCSEC-2021-12 Codecov security event and HashiCorp GPG key exposure, 22 Apr 2021	discuss.hashicorp.com	2026-11-03	Confirmed
92	CISA, AA21-042A Compromise of U.S. Water Treatment Facility, Feb 2021	cisa.gov	2026-11-03	Confirmed
93	PHP internals mailing list, php-src commit incident, 28 Mar 2021	news-web.php.net	2026-11-03	Confirmed
94	Meta, "The Facts on News Reports About Facebook Data", 6 Apr 2021	about.fb.com	2026-11-03	Confirmed
95	Ireland Data Protection Commission, decision in the Facebook data scraping inquiry, 25 Nov 2022	dataprotection.ie	2026-11-03	Confirmed
96	NVD, CVE-2021-30120 detail	nvd.nist.gov	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
97	Europol, "Five affiliates to Sodinokibi/REvil unplugged" (title readable; date not checked)	europol.europa.eu	2026-11-03	Confirmed
98	MITRE ATT&CK, software S0496 REvil	attack.mitre.org	2026-11-03	Confirmed
99	T-Mobile, "Additional Information Regarding 2021 Cyberattack Investigation", 17 and 20 Aug 2021	t-mobile.com	2026-11-03	Confirmed
100	T-Mobile, CEO letter on the cyberattack, 27 Aug 2021	t-mobile.com	2026-11-03	Confirmed
101	Wiz, "ChaosDB: How we hacked thousands of Azure customers' databases", 26 Aug 2021	wiz.io	2026-11-03	Demonstrated
102	MSRC, update on the Azure Cosmos DB Jupyter Notebook vulnerability, 27 Aug 2021	microsoft.com	2026-11-03	Confirmed
103	UpGuard, Power Apps data exposure, 23 Aug 2021	upguard.com	2026-11-03	Confirmed
104	Wiz, "OMIGOD: Critical Vulnerabilities in OMI Affecting Countless Azure Customers", 14 Sep 2021	wiz.io	2026-11-03	Confirmed
105	NVD, CVE-2021-38647 detail	nvd.nist.gov	2026-11-03	Confirmed
106	Palo Alto Networks Unit 42, "Azurescape", 9 Sep 2021	unit42.paloaltonetworks.com	2026-11-03	Demonstrated
107	Twitch, "Updates on the Twitch Security Incident", 15 Oct 2021	blog.twitch.tv	2026-11-03	Confirmed
108	CISA alert, malware discovered in popular npm package ua-parser-js, 22 Oct 2021	cisa.gov	2026-11-03	Confirmed
109	GitHub Advisory Database, GHSA-pjwm-rvh2-c87w, 22 Oct 2021	github.com	2026-11-03	Confirmed
110	NVD, CVE-2021-27101 detail (with the Accellion records)	nvd.nist.gov	2026-11-03	Confirmed
111	MITRE ATT&CK, group G0125 HAFNIUM	attack.mitre.org	2026-11-03	Confirmed
112	MITRE ATT&CK, campaign C0024 SolarWinds Compromise	attack.mitre.org	2026-11-03	Confirmed
113	MITRE ATT&CK, group G0016 APT29	attack.mitre.org	2026-11-03	Confirmed
114	MITRE ATT&CK, software S0559 SUNBURST	attack.mitre.org	2026-11-03	Confirmed
115	MITRE ATT&CK, technique T1701 Command and Scripting Interpreter (ICS)	attack.mitre.org	2026-11-03	Confirmed
116	MITRE ATT&CK, group G0102 Wizard Spider	attack.mitre.org	2026-11-03	Confirmed
117	MITRE ATT&CK, campaign C0017	attack.mitre.org	2026-11-03	Confirmed
118	MITRE ATT&CK, software S0575 Conti	attack.mitre.org	2026-11-03	Confirmed
119	Red Canary, 2022 Threat Detection Report (2021 data)	resource.redcanary.com	2026-11-03	Confirmed
120	NIST, EO-critical software definition, explanatory material	nist.gov	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
121	NTIA, The Minimum Elements for a Software Bill of Materials (PDF), 12 Jul 2021	ntia.gov	2026-11-03	Confirmed
122	NTIA, SBOM minimum elements report page	ntia.gov	2026-11-03	Confirmed
123	OMB, M-22-09 Moving the U.S. Government Toward Zero Trust Cybersecurity Principles, 26 Jan 2022	whitehouse.gov	2026-11-03	Confirmed
124	CISA, Zero Trust Maturity Model	cisa.gov	2026-11-03	Confirmed
125	CISA, Cyber Safety Review Board	cisa.gov	2026-11-03	Confirmed
126	DHS, new cybersecurity requirements for critical pipeline owners and operators, 27 May 2021	dhs.gov	2026-11-03	Confirmed
127	DHS, new cybersecurity requirements for critical pipeline owners and operators, 20 Jul 2021	dhs.gov	2026-11-03	Confirmed
128	Federal Reserve, FDIC and OCC, computer-security incident notification rule, 18 Nov 2021	federalreserve.gov	2026-11-03	Confirmed
129	CISA, Cyber Incident Reporting for Critical Infrastructure Act of 2022	cisa.gov	2026-11-03	Confirmed
130	The White House (archive), National Security Memorandum on Improving Cybersecurity for Critical Infrastructure Control Systems, 28 Jul 2021	bidenwhitehouse.archives.gov	2026-11-03	Confirmed
131	MITRE ATT&CK, updates April 2021 (v9)	attack.mitre.org	2026-11-03	Confirmed
132	MITRE ATT&CK, updates October 2021 (v10)	attack.mitre.org	2026-11-03	Confirmed
133	MITRE D3FEND, About	d3fend.mitre.org	2026-11-03	Confirmed
134	TeamStarWolf library, ATT&CK, D3FEND and CWE data files (`data/attack/`, `data/weaknesses/`) and generated pages (`mitre/`)	github.com/TeamStarWolf/TeamStarWolf	2026-11-03	Confirmed
135	TeamStarWolf library, `scripts/validate_navigator.py`	github.com/TeamStarWolf/TeamStarWolf	2026-11-03	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference

- CWE Reference, CAPEC Reference, D3FEND Reference
- Ransomware Defense Reference, Edge Device Security Reference, Email Security Reference, Cloud Attack Reference, Mobile Security Reference, ICS/OT Security Reference, Incident Response Reference
- Supply Chain Security, Vulnerability Prioritization Reference
- Home studies: Operation Exchange Marauder and the 2021 Exchange Server Mass Exploitation; SolarWinds and SUNBURST, 2019 to 2021; APT41: the public record; Log4Shell; the Cl0p file-transfer study
- Series and related studies: The Year 2019 in Intrusions, China-Attributed Threat Actors: The Public Record, Russia-Attributed Threat Actors: The Public Record, The Year 2020 in Intrusions, Stuxnet, Industrial control system attacks and advisories, 2024 to 2026, npm supply-chain attacks
- Groups: G0125 HAFNIUM, G1023 APT5, G0016 APT29, G0065 Leviathan, G0128 ZIRCONIUM, G0004 Ke3chang, G0096 APT41, G0059 Magic Hound, G1012 CURIUM, G0049 OilRig, G0032 Lazarus Group, G0115 GOLD SOUTHFIELD, G0102 Wizard Spider, G0092 TA505
- Campaigns: C0024 SolarWinds Compromise, C0017, C0015
- Software: S0559 SUNBURST, S0661 FoggyWeb, S0634 EnvyScout, S0635 BoomBox, S0636 VaporRage, S0637 NativeZone, S0514 WellMess, S1104 SLOWPULSE, S1108 PULSECHECK, S0584 AppleJeus, S0496 REvil, S0575 Conti, S0367 Emotet, S0266 TrickBot, S0611 Clop, S0640 Avaddon, S0618 FIVEHANDS, S0154 Cobalt Strike, S0002 Mimikatz
- Techniques: T1190 Exploit Public-Facing Application, T1505.003 Web Shell, T1556.004 Network Device Authentication, T1110.003 Password Spraying, T1566.002 Spearphishing Link, T1199 Trusted Relationship, T1072 Software Deployment Tools, T1195.002 Compromise Software Supply Chain, T1486 Data Encrypted for Impact
- CAPEC: CAPEC-664, CAPEC-586, CAPEC-126, CAPEC-66, CAPEC-88
- Navigator layers, including this study's layers, chronicle-2021.json and chronicle-2021-ics.json